BTS SIO · OPTION SISR · 1RE ANNÉE · BLOC 3

Thème 2
Préserver l'identité numérique de l'organisation

Cours complet en 5 séances de 2 h · Ateliers Kali Linux en laboratoire isolé · Exercices corrigés

```
┌──(kali㉿kali)-[~/identite-numerique]
└─$ dig lab.cybernova.test TXT +short
"v=spf1 mx include:_spf.mailprovider.example -all"
┌──(kali㉿kali)-[~/identite-numerique]
└─$ echo "Observer. Mesurer. Protéger. Prouver."
Observer. Mesurer. Protéger. Prouver.
```

TWAGIRUMUKIZA · Document pédagogique · Domaines et adresses fictifs (CyberNova, example.com, plages réservées à la documentation) · Toutes les manipulations se font uniquement sur des systèmes autorisés

Sommaire

Présentation du thème 4
Objectifs et compétences visées 4
Progression des 5 séances 4
Prérequis 4
Évaluation 5
Comment lire les consoles de ce document 5
Préparer le laboratoire Kali 5

Séance 1 — Les composants de l'identité numérique 7
1.1 Objectifs pédagogiques 7
1.2 Mise en situation : le cas CyberNova 7
1.3 Définition et trois dimensions 7
1.4 Les composants techniques et organisationnels 8
1.5 Le nom de domaine et le DNS 8
1.6 Les certificats TLS 9
1.7 Comptes officiels, marque et e-réputation 9
1.8 Pourquoi protéger l'identité numérique : les enjeux 10
1.9 Exercice d'application : cas CyberNova 13
1.10 Synthèse à retenir 14

Séance 2 — Les menaces sur l'identité numérique 16
2.1 Objectifs pédagogiques 16
2.2 Panorama : trois familles de menaces 16
2.3 L'usurpation d'identité numérique 16
2.4 Le typosquatting et les attaques par homographe 16
2.5 Le spoofing et le phishing ciblé 17
2.6 Faux comptes, vol de comptes, défiguration et e-réputation 17
2.7 Dimension juridique : usurpation, diffamation, dénigrement 18
2.8 Conséquences économiques et risque humain 18
2.9 Scénario d'attaque type (kill chain simplifiée) 18
2.10 Exercice d'application : tableau des menaces (livrable) 22
2.11 Synthèse à retenir 22

Séance 3 — Les mesures de protection 24
3.1 Objectifs pédagogiques 24
3.2 Logique de défense : prévenir, détecter, réagir 24
3.3 Protéger le nom de domaine 24
3.4 Protéger la messagerie : SPF, DKIM, DMARC 24
3.5 DNSSEC et CAA 26
3.6 Gérer les certificats 26
3.7 Sécuriser les comptes officiels 26
3.8 Surveiller la marque et les domaines 27
3.9 Évaluer le risque et choisir les mesures 27
3.10 Exercice : plan de protection CyberNova (livrable) 30
3.11 Synthèse à retenir 31

Séance 4 — Atelier Kali : audit d'identité numérique 32
4.1 Objectifs pédagogiques 32
4.2 Cadre légal et déontologique 32
4.3 Déroulé de l'atelier (2 h) 32

4.4 Étape 0 — Préparer le dossier de travail et la traçabilité ... 33
4.5 Étape 1 — Cartographier le DNS (dig, dnsrecon) ... 33
4.6 Étape 2 — Détecter des domaines imitateurs (dnstwist) ... 35
4.7 Étape 3 — Auditer le certificat et la configuration TLS ... 35
4.8 Étape 4 — En-têtes HTTP de sécurité (curl) ... 37
4.9 Étape 5 — Mesurer l'exposition publique (theHarvester, laboratoire uniquement) ... 37
4.10 Étape 6 — Figer les preuves et clore la session ... 38
4.11 Structure du rapport d'audit (livrable) ... 39
4.12 Critères d'évaluation du rapport (sur 20) ... 39

Séance 5 — Procédures de réaction et synthèse ... 41
5.1 Objectifs pédagogiques ... 41
5.2 Les cinq phases de la réaction ... 41
5.3 Préserver les preuves ... 41
5.4 Signaler et obtenir le retrait ... 45
5.5 Lien avec le RGPD ... 46
5.6 Communication de crise ... 46
5.7 Procédure type de signalement d'usurpation (livrable : modèle) ... 47
5.8 Étude de cas finale (évaluation sommative, 45 min) ... 47
5.9 Synthèse du thème ... 48

Annexes ... 50
A. Méthode de réponse à une question d'examen BTS SIO ... 50
B. Aide-mémoire des commandes Kali du thème ... 50
C. QCM de synthèse du thème (12 questions) ... 51
D. Grille d'évaluation de la fiche d'identité numérique (séance 1) ... 52
E. Glossaire ... 52
F. Points de vigilance pour le formateur ... 53

Présentation du thème

Ce thème apprend à reconnaître, protéger et défendre l'identité numérique d'une organisation : son domaine, ses certificats, ses comptes officiels, sa marque et sa réputation en ligne. Il comprend 5 séances de 2 h, soit 10 h, et s'appuie sur un fil rouge unique : l'entreprise fictive **CyberNova** (domaine officiel `cybernova.fr`, 40 salariés, vente de services en ligne).

Objectifs et compétences visées

- Définir l'identité numérique d'une organisation et distinguer ses dimensions déclarative, agissante et calculée.
- Lire un enregistrement DNS, un certificat TLS et un en-tête d'e-mail.
- Identifier et qualifier les menaces d'usurpation : typosquatting, spoofing, phishing ciblé, faux comptes, défiguration.
- Mettre en œuvre ou recommander des protections : SPF, DKIM, DMARC, DNSSEC, gestion des certificats, MFA, surveillance de marque.
- Réaliser un audit passif d'identité numérique dans un cadre autorisé (ateliers Kali en environnement isolé).
- Rédiger une procédure de signalement et de réaction, en conservant les preuves de façon exploitable.
- Justifier ses choix par une analyse de risque (probabilité, gravité, coût de la mesure).

Progression des 5 séances

Séance	Titre	Notion centrale	Ateliers Kali	Livrable
1	Composants de l'identité numérique	Ce qui identifie l'organisation en ligne	K1 : DNS et certificat	Fiche d'identité numérique
2	Menaces sur l'identité numérique	Comment l'identité est imitée, détournée, attaquée	K2 : en-têtes, variantes de domaine	Tableau des menaces
3	Mesures de protection	Rendre l'usurpation difficile et détectable	K3 : SPF, DKIM, DMARC, CAA, DNSSEC	Plan de protection
4	Atelier : audit d'identité numérique	Observer et mesurer l'exposition réelle	K4 : audit complet en 6 étapes	Rapport d'audit
5	Réaction et synthèse	Réagir, prouver, communiquer	K5 : collecte et intégrité des preuves	Procédure de signalement

Prérequis

- Notions de réseau : adresse IP, port, modèle client-serveur, HTTP/HTTPS.
- Utilisation basique d'un terminal Linux (navigation, redirections, tubes).

- Notions de RGPD du Thème 1 : données personnelles, notification de violation sous 72 h, analyse de risques.

Évaluation

Type	Support	Critères
Formative	QCM et exercices de chaque séance	Exactitude, justification
Pratique	Rapport d'audit (séance 4)	Grille sur 20 points (voir séance 4)
Sommative	Étude de cas finale (séance 5)	Méthode de réponse d'examen BTS SIO (annexe A)

> **Règle d'or des ateliers Kali**
>
> Toutes les manipulations se font **sur un domaine que vous possédez, sur un domaine réservé aux exemples (`example.com`) ou dans le laboratoire virtuel isolé**. Aucune action ne vise un système tiers sans autorisation écrite : en droit français, l'accès ou le maintien frauduleux dans un système de traitement automatisé de données est une infraction pénale (articles 323-1 et suivants du Code pénal).

Comment lire les consoles de ce document

Les exercices Kali sont présentés dans des fenêtres de terminal au format Kali Linux : prompt à deux lignes `┌──(kali㉿kali)-[répertoire]` puis `└─$`, commandes en vert, options en cyan, chaînes de caractères en jaune. Les sorties sont des **simulations pédagogiques** construites sur des domaines et adresses fictifs (`lab.cybernova.test`, plages `203.0.113.0/24` et `198.51.100.0/24` réservées à la documentation). Sur votre laboratoire, les valeurs exactes différeront selon votre configuration et la version des outils.

Couleur	Signification dans les sorties
vert	Résultat conforme, bonne pratique, succès
jaune	Information à surveiller, valeur à interpréter
rouge	Faiblesse, anomalie, risque identifié
cyan	Noms d'enregistrements, champs techniques, titres de sections
gris	Commentaires, éléments secondaires

Préparer le laboratoire Kali

Machine virtuelle Kali Linux sur un réseau virtuel isolé, avec un DNS de laboratoire fourni par le formateur. Avant la première séance, vérifiez l'environnement et la présence des outils.

Préparation du laboratoire — kali@kali

```
┌──(kali㉿kali)-[~]
└─$ cat /etc/os-release | head -3
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2026.3"
```

```
┌──(kali㉿kali)-[~]
└─$ which dig openssl dnsrecon dnstwist sslscan testssl.sh theHarvester whois curl sha256sum
/usr/bin/dig
/usr/bin/openssl
/usr/bin/dnsrecon
/usr/bin/dnstwist
/usr/bin/sslscan
/usr/bin/testssl.sh
/usr/bin/theHarvester
/usr/bin/whois
/usr/bin/curl
/usr/bin/sha256sum
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/identite-numerique/$(date +%F) && cd ~/identite-numerique/$(date +%F)
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ pwd
/home/kali/identite-numerique/2026-10-23
```

Signification des lignes de commande

Commande ou ligne	Signification
`cat /etc/os-release | head -3`	`cat` affiche le fichier qui décrit la distribution ; le tube `|` envoie ce texte à `head -3`, qui ne garde que les 3 premières lignes. Objectif : vérifier qu'on travaille bien sur Kali et noter sa version.
`which dig openssl dnsrecon … sha256sum`	`which` cherche chaque programme dans les répertoires du `PATH` et affiche son chemin. Une ligne = outil installé ; aucune ligne pour un nom = outil absent, à installer avant la séance.
`mkdir -p ~/identite-numerique/$(date +%F) && cd ~/identite-numerique/$(date +%F)`	`mkdir -p` crée le dossier (et ses parents) sans erreur s'il existe déjà. `$(date +%F)` est remplacé par la date au format AAAA-MM-JJ. `&&` n'exécute la suite que si la création a réussi ; `cd` se place alors dans le dossier du jour.
`pwd`	Affiche le répertoire courant pour confirmer qu'on est au bon endroit avant de lancer les relevés.

Si un outil manque

Sur Kali, installez-le avec `sudo apt update && sudo apt install dnsrecon dnstwist sslscan testssl.sh theharvester` . Les noms de paquets peuvent varier légèrement selon la version : consultez `apt search` si besoin. Cette opération se fait avant la séance, sur le réseau autorisé par le formateur.

Séance 1 — Les composants de l'identité numérique

Durée : 2 h · Cours théorique et pratique · Atelier Kali K1 · Livrable : fiche d'identité numérique de l'organisation

1.1 Objectifs pédagogiques

- Définir l'identité numérique d'une organisation et ses trois dimensions.
- Identifier ses composants : nom de domaine, DNS, certificats TLS, comptes officiels, marque, e-réputation.
- Expliquer pourquoi cette identité est un enjeu de sécurité.
- Lire un enregistrement DNS et un certificat avec les outils Kali.
- Proposer de premières mesures de protection.

1.2 Mise en situation : le cas CyberNova

L'entreprise CyberNova possède un site officiel (`https://www.cybernova.fr`), une messagerie professionnelle et une page LinkedIn. Un attaquant enregistre `cyber-nova.fr`, copie le logo et envoie aux clients un faux message de relance de facture. Un client saisit ses identifiants bancaires sur le faux site.

L'entreprise a-t-elle été piratée ? **Pas nécessairement** : l'attaquant n'a pas eu besoin d'entrer dans son système d'information. Il lui a suffi d'imiter son identité. Protéger l'identité numérique, c'est donc empêcher des tiers de se faire passer pour l'organisation, ses collaborateurs ou ses services.

1.3 Définition et trois dimensions

L'**identité numérique d'une organisation** est l'ensemble des éléments qui permettent de la reconnaître en ligne, de retrouver ses services et, sous conditions, de vérifier l'authenticité de ses communications.

Dimension	Définition	Exemples pour une organisation
Déclarative	Ce que l'organisation choisit de publier	Dénomination, logo, adresse, site officiel, comptes officiels
Agissante	Les traces laissées par ses activités en ligne	Consultations de sites par les employés, publications, interactions, activité des comptes
Calculée	Les déductions produites à partir des deux premières, souvent par algorithmes	Estimation de l'activité à partir de la fréquentation du site, score de réputation, profilage

> **À retenir pour l'examen**
> La dimension déclarative se maîtrise, la dimension agissante se limite, la dimension calculée se subit en grande partie. Une organisation qui ne surveille que ce qu'elle publie ignore une grande partie de son identité réelle.

1.4 Les composants techniques et organisationnels

Composant	Rôle	Risque principal
Nom de domaine	Adresse lisible des services (`cybernova.fr`)	Perte, détournement, imitation
DNS	Publie les informations associées au domaine	Modification frauduleuse, usurpation de zone
Certificat TLS	Associe un domaine à une clé publique, chiffre la connexion	Expiration, certificat mal émis, fausse confiance
Messagerie professionnelle	Communication officielle (`contact@cybernova.fr`)	Usurpation d'expéditeur (spoofing)
Comptes officiels	LinkedIn, X, Instagram, application mobile	Vol de compte, faux comptes
Marque et signes distinctifs	Nom commercial, logo, charte graphique	Copie pour crédibiliser une fraude
Adresses IP publiques, cookies, géolocalisation, signatures électroniques	Traces et mécanismes techniques d'identification	Exploitation des traces, falsification
E-réputation	Opinions exprimées sur Internet et les réseaux sociaux	Faux avis, publications trompeuses, dénigrement

Les noms de domaine internationalisés (IDN) méritent une attention particulière : certains caractères d'autres alphabets ressemblent visuellement à des lettres latines (un `a` cyrillique peut imiter un `a` latin). C'est l'attaque par homographe.

1.5 Le nom de domaine et le DNS

Décomposition d'une adresse. Dans `www.cybernova.fr` : `fr` est l'extension (domaine de premier niveau), `cybernova` le nom choisi par l'organisation, `www` un sous-domaine. Un certificat valable pour `cybernova.fr` ne couvre pas forcément `paiement.cybernova.fr`.

1. L'utilisateur
saisit `www.cybernova.fr` dans le navigateur

2. Le résolveur DNS
interroge les serveurs faisant autorité et obtient l'adresse IP

3. Le serveur web
reçoit la connexion TLS et présente son certificat

4. Le navigateur
vérifie le certificat puis affiche la page

Le DNS ne garantit pas, à lui seul, qu'un site est légitime : un attaquant peut posséder un domaine tout à fait valide qui ressemble au vôtre.

Type	Fonction	Exemple d'usage
`A`	Associe un nom à une adresse IPv4	Serveur web
`AAAA`	Associe un nom à une adresse IPv6	Serveur compatible IPv6
`MX`	Désigne les serveurs de réception des e-mails	Messagerie professionnelle
`TXT`	Stocke du texte libre	SPF, DMARC, vérification de domaine
`CNAME`	Crée un alias vers un autre nom	`www` vers le nom du serveur
`NS`	Désigne les serveurs DNS faisant autorité pour la zone	Délégation de la zone

> **Point d'examen**
> Un enregistrement `MX` concerne la **réception** des e-mails. Les mécanismes SPF, DKIM et DMARC, qui protègent l'**émission**, reposent notamment sur des enregistrements `TXT` (séance 3).

1.6 Les certificats TLS

Un **certificat TLS** est un document numérique qui associe un nom de domaine à une clé publique, vérifiable grâce à une chaîne de confiance (certificat du serveur, autorité intermédiaire, autorité racine reconnue par le navigateur). Le terme « SSL » reste courant, mais les connexions modernes utilisent TLS, qui a succédé à SSL. Un certificat contribue à trois objectifs : **authentification** (certificat valide pour le nom consulté), **confidentialité** (connexion chiffrée), **intégrité** (modification détectable des données).

> **Limite essentielle : le cadenas ne prouve pas l'honnêteté du site**
> Un site frauduleux peut obtenir un certificat valide pour son propre domaine, y compris gratuitement. Le certificat prouve que vous parlez bien au détenteur de `cyber-nova.fr`, pas que ce détenteur est CyberNova.

Élément du certificat	Question à se poser
Nom de domaine (CN / SAN)	Le certificat couvre-t-il exactement le domaine consulté ?
Émetteur	Quelle autorité de certification l'a délivré ?
Validité (`notBefore`, `notAfter`)	Est-il dans sa période de validité ?
Chaîne de confiance	Le navigateur peut-il la valider jusqu'à une racine reconnue ?
Usage	Convient-il à l'usage prévu (authentification serveur) ?

1.7 Comptes officiels, marque et e-réputation

L'identité numérique dépasse le site web. Une organisation est aussi représentée par une page LinkedIn, des comptes sociaux, des adresses e-mail, un espace client, une application mobile, un logo et une marque déposée. Chacun est un point d'entrée possible pour une fraude.

Exemple. Un pirate récupère le mot de passe du compte LinkedIn d'un dirigeant et publie une fausse offre d'emploi qui redirige les candidats vers un formulaire frauduleux. Conséquences : collecte de données personnelles, vol d'identifiants, atteinte à l'image, perte de confiance.

E-réputation. Une organisation peut conserver un système informatique opérationnel tout en subissant une grave perte de confiance à cause de publications trompeuses, de faux avis ou de l'usurpation de ses comptes. La protection doit couvrir les composants techniques, les accès aux comptes et la surveillance de ce qui se publie en son nom.

1.8 Pourquoi protéger l'identité numérique : les enjeux

Enjeu	Description
Financier	Fraude au faux fournisseur ou au faux président : virement vers un compte contrôlé par un fraudeur.
Confiance	Des clients croient l'organisation responsable d'une escroquerie.
Juridique	Si des données personnelles sont compromises : obligations RGPD (notification à la CNIL sous 72 h dans les cas prévus, information des personnes).
Sécurité	Un domaine détourné ou un compte compromis sert à diffuser des logiciels malveillants, collecter des mots de passe ou mener des attaques ciblées.

Atelier Kali K1 — Observer l'identité numérique d'un domaine (40 min)

Objectif : lire des informations techniques publiques en consultation passive. **Cible :** le domaine de laboratoire `lab.cybernova.test` fourni par le formateur (ou `example.com` en consultation passive). Les sorties ci-dessous sont des simulations sur un domaine fictif.

Exercice K1.1 — Interroger le DNS

Relevez l'adresse IPv4, les serveurs de messagerie et les enregistrements texte du domaine.

K1.1 — Enregistrements DNS — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test A +noall +answer
lab.cybernova.test.        3600    IN      A       203.0.113.10
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test MX +noall +answer
lab.cybernova.test.        3600    IN      MX      10 mail.lab.cybernova.test.
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test TXT +short
"v=spf1 mx include:_spf.mailprovider.example -all"
"google-site-verification=Zk3b...fictif"
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test NS +short
ns1.lab.cybernova.test.
ns2.lab.cybernova.test.
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig www.lab.cybernova.test CNAME +short
```

```
lab.cybernova.test.
```

Signification des lignes de commande

Commande ou ligne	Signification
`dig lab.cybernova.test A +noall +answer`	`dig` interroge le DNS. `A` demande l'adresse IPv4. `+noall` masque toutes les sections de la réponse, `+answer` réaffiche uniquement la section « réponse » : on obtient une ligne lisible (nom, durée de vie TTL, classe `IN`, type, valeur).
`dig lab.cybernova.test MX +noall +answer`	Même principe pour les serveurs de messagerie (`MX`). La valeur « 10 mail... » est la priorité (le plus petit nombre est contacté en premier) suivie du nom du serveur.
`dig lab.cybernova.test TXT +short`	`TXT` demande les enregistrements texte ; `+short` n'affiche que la valeur. On y lit la politique SPF (`v=spf1`) et une chaîne de vérification de propriété du domaine.
`dig lab.cybernova.test NS +short`	Liste les serveurs de noms (`NS`) qui font autorité pour la zone, donc le ou les prestataires dont dépend le domaine.
`dig www.lab.cybernova.test CNAME +short`	Affiche la cible de l'alias (`CNAME`) : ici `www` est un autre nom pour le domaine principal.

Questions. (1) À quoi sert l'enregistrement TXT qui commence par `v=spf1` ? (2) Pourquoi le `MX` porte-t-il une priorité de 10 ? (3) Quelle information révèle l'enregistrement `NS` sur la dépendance de l'organisation envers ses prestataires ?

Exercice K1.2 — Lire la réponse DNS complète

La sortie complète de `dig` contient des informations utiles à l'audit : serveur interrogé, statut, durée de vie.

K1.2 — Sortie complète de dig — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test A
; <<>> DiG 9.20.2-1-Debian <<>> lab.cybernova.test A
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 41872
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; QUESTION SECTION:
;lab.cybernova.test.            IN      A

;; ANSWER SECTION:
lab.cybernova.test.     3600        IN      A       203.0.113.10

;; Query time: 12 msec
;; SERVER: 192.168.56.2#53(192.168.56.2) (UDP)
```

```
;; WHEN: Fri Oct 23 09:14:02 CEST 2026
;; MSG SIZE  rcvd: 62
```

Signification des lignes de commande

Commande ou ligne	Signification
`dig lab.cybernova.test A`	Sans option d'affichage, `dig` donne la réponse complète. Les lignes à savoir lire :
`; <<>> DiG … <<>> lab.cybernova.test A`	Rappel de la version de `dig` et de la requête envoyée.
`;; ->>HEADER<<- … status: NOERROR`	En-tête de la réponse. `NOERROR` : la requête a abouti ; `NXDOMAIN` signifierait que le nom n'existe pas. `id` relie la question à la réponse.
`;; flags: qr rd ra`	`qr` : c'est une réponse ; `rd` : la récursion a été demandée ; `ra` : le serveur sait faire de la récursion.
`;; QUESTION SECTION`	Rappelle la question posée : nom, classe `IN` (Internet), type `A`.
`;; ANSWER SECTION`	La réponse : le nom, le **TTL** (3600 s = durée de conservation en cache) et l'adresse IPv4 `203.0.113.10`.
`;; Query time / SERVER / WHEN / MSG SIZE`	Durée de la requête, serveur DNS qui a répondu (ici le résolveur du laboratoire, en UDP port 53), date de la requête et taille de la réponse. La date et le serveur sont utiles pour documenter un relevé.

Questions. (4) Que signifie `status: NOERROR` ? Que signifierait `NXDOMAIN` ? (5) Que représente la valeur 3600 et pourquoi est-elle importante lors d'un changement d'adresse ? (6) Quel serveur a répondu ?

Exercice K1.3 — Observer le certificat TLS

K1.3 — Certificat TLS du serveur — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ openssl s_client -connect lab.cybernova.test:443 -servername lab.cybernova.test </dev/null 2
>/dev/null | openssl x509 -noout -subject -issuer -dates
subject=CN = lab.cybernova.test
issuer=C = FR, O = CyberNova Lab CA, CN = CyberNova Lab Issuing CA
notBefore=Sep  1 08:00:00 2026 GMT
notAfter=Nov 30 08:00:00 2026 GMT
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ openssl s_client -connect lab.cybernova.test:443 -servername lab.cybernova.test </dev/null 2
>/dev/null | openssl x509 -noout -ext subjectAltName
X509v3 Subject Alternative Name:
    DNS:lab.cybernova.test, DNS:www.lab.cybernova.test
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ echo | openssl s_client -connect lab.cybernova.test:443 -servername lab.cybernova.test 2>/
dev/null | grep -E "Verify return code|Protocol|Cipher"
```

```
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
    Protocol  : TLSv1.3
    Verify return code: 20 (unable to get local issuer certificate)
```

Signification des lignes de commande

Commande ou ligne	Signification
`openssl s_client -connect lab.cybernova.test:443 -servername lab.cybernova.test </dev/null 2>/dev/null | openssl x509 -noout -subject -issuer -dates`	`s_client` ouvre une connexion TLS vers le port 443. `-servername` envoie le nom demandé (SNI) pour que le serveur présente le bon certificat. `</dev/null` ferme l'entrée pour que la commande se termine seule ; `2>/dev/null` masque les messages d'erreur. Le tube passe le certificat à `openssl x509` : `-noout` n'affiche pas le certificat brut, `-subject` son titulaire, `-issuer` l'autorité émettrice, `-dates` les dates `notBefore` et `notAfter` (validité).
`… | openssl x509 -noout -ext subjectAltName`	Affiche l'extension **SAN** : la liste des noms que le certificat couvre réellement. Un nom absent de cette liste n'est pas couvert.
`echo | openssl s_client … 2>/dev/null | grep -E "Verify return code|Protocol|Cipher"`	`echo` envoie une ligne vide pour terminer la session. `grep -E` filtre avec une expression étendue : on ne garde que le protocole négocié, la suite de chiffrement et le code de vérification de la chaîne de confiance (`20` = émetteur local inconnu, normal en laboratoire).

Questions. (7) Quelle est la date d'expiration et combien de jours restent-ils au 23 octobre 2026 ? (8) `paiement.lab.cybernova.test` est-il couvert par ce certificat ? (9) Pourquoi le code de vérification est-il en erreur dans le laboratoire, et cette erreur serait-elle acceptable sur un site public ?

Exercice K1.4 — Compléter le compte rendu

Élément observé	Résultat	Interprétation
Enregistrement A	*à relever*	Adresse IPv4 publiée, si présente
Enregistrement MX	*à relever*	Serveurs de réception des e-mails
Enregistrement TXT	*à relever*	Informations publiées (SPF, vérifications)
Sujet du certificat	*à relever*	Identité déclarée dans le certificat
Émetteur	*à relever*	Autorité de certification
Date d'expiration	*à relever*	Validité temporelle à surveiller

Ne concluez jamais qu'un domaine est sûr uniquement parce qu'il a un certificat TLS ou un DNS bien configuré.

1.9 Exercice d'application : cas CyberNova

Événements constatés : le domaine officiel est `cybernova.fr` ; un domaine `cyber-nova.fr` apparaît dans un e-mail suspect ; le site suspect utilise HTTPS ; un faux compte LinkedIn reprend le logo ; le service informatique ignore qui détient les droits d'administration du compte LinkedIn officiel.

1. Quel élément de l'identité numérique est imité par `cyber-nova.fr` ? (le certificat uniquement / le nom de domaine / l'adresse IP uniquement)

2. Le cadenas HTTPS prouve-t-il que le site appartient à CyberNova ? (oui, toujours / non, pas à lui seul / oui, s'il affiche le logo officiel)
3. Quel est le risque principal du faux compte LinkedIn ? (usurpation de l'identité de l'organisation / panne du DNS / expiration du certificat)
4. Quelle action est prioritaire pour le compte officiel ? (partager le mot de passe / inventorier les responsables, sécuriser les accès et activer la MFA / supprimer le nom de domaine)

> **Corrigés de la séance 1**
>
> **Exercice K1.1.** (1) L'enregistrement SPF liste les serveurs autorisés à envoyer du courrier pour le domaine ; `-all` demande de rejeter les autres. (2) La priorité ordonne les serveurs : le plus petit nombre est contacté en premier ; avec un seul MX, la valeur n'a pas d'effet pratique mais reste obligatoire. (3) Les serveurs de noms désignent qui héberge la zone DNS : si ce prestataire est compromis ou indisponible, le domaine l'est aussi.
>
> **Exercice K1.2.** (4) `NOERROR` : la requête a réussi ; `NXDOMAIN` : le nom n'existe pas. (5) 3600 est le TTL en secondes (1 h) : durée pendant laquelle les résolveurs gardent la réponse en cache ; un TTL long retarde la propagation d'un changement d'adresse. (6) Le serveur `192.168.56.2` (résolveur du laboratoire).
>
> **Exercice K1.3.** (7) Expiration le 30 novembre 2026 : 38 jours restants au 23 octobre (8 jours d'octobre + 30 jours de novembre) ; à surveiller et à renouveler avant l'échéance. (8) Non : seuls `lab.cybernova.test` et `www.lab.cybernova.test` figurent dans les SAN ; un certificat joker (`*.lab.cybernova.test`) serait nécessaire. (9) L'autorité émettrice est une autorité de laboratoire non reconnue par le système ; acceptable en laboratoire, **inacceptable** sur un site public où les navigateurs afficheraient une alerte.
>
> **Cas CyberNova.** 1 : le nom de domaine ; 2 : non, pas à lui seul ; 3 : l'usurpation de l'identité de l'organisation ; 4 : inventorier les responsables, sécuriser les accès et activer la MFA.

1.10 Synthèse à retenir

Notion	Définition à savoir expliquer
Identité numérique	Ensemble des éléments qui identifient et représentent une organisation en ligne
Déclarative, agissante, calculée	Ce qui est publié, les traces de l'activité, les interprétations déduites
Nom de domaine	Nom utilisé pour accéder à un service sur Internet
DNS	Système de résolution et de publication d'informations liées aux noms de domaine
Certificat TLS	Document numérique associant un domaine à une clé publique et sécurisant la connexion
Compte officiel	Compte utilisé pour communiquer au nom de l'organisation
E-réputation	Opinion publique en ligne sur l'organisation
Usurpation	Utilisation frauduleuse de l'identité ou de l'apparence d'un tiers
Typosquatting	Domaine proche d'un domaine légitime, enregistré pour tromper les internautes

Déroulé pédagogique (2 h)

Horaire	Activité
0 h 00 – 0 h 10	Introduction et mise en situation CyberNova
0 h 10 – 0 h 35	Trois dimensions, nom de domaine et DNS
0 h 35 – 0 h 55	Certificats TLS et leurs limites
0 h 55 – 1 h 10	Comptes officiels, marque, e-réputation
1 h 10 – 1 h 50	Atelier Kali K1 et cas CyberNova
1 h 50 – 2 h 00	Synthèse, annonce de la séance 2

Livrable : fiche d'identité numérique de l'organisation étudiée, listant domaines, certificats, comptes officiels, risques et premières mesures de protection.

Séance 2 — Les menaces sur l'identité numérique

Durée : 2 h · Atelier Kali K2 · Livrable : tableau des menaces et de leurs conséquences

2.1 Objectifs pédagogiques

- Distinguer usurpation, typosquatting, spoofing, phishing ciblé, défiguration et atteinte à l'e-réputation.
- Décrire le scénario type d'une attaque contre l'identité d'une organisation.
- Qualifier les conséquences techniques, financières, juridiques et réputationnelles.
- Repérer les indices d'un domaine ou d'un message frauduleux, à la main et avec les outils Kali.

2.2 Panorama : trois familles de menaces

Une attaque contre l'identité numérique ne cherche pas toujours à pénétrer le système d'information.

Famille	Principe	Exemples
Imitation	L'attaquant crée une fausse identité crédible	Typosquatting, faux site, faux compte, homographe
Détournement	L'attaquant prend le contrôle d'un élément réel	Vol de compte, détournement de domaine, défiguration
Atteinte à la réputation	L'attaquant nuit à la perception de l'organisation	Faux avis, campagne de dénigrement, diffamation

2.3 L'usurpation d'identité numérique

L'**usurpation** consiste à utiliser le nom, les données, le logo ou l'apparence d'une organisation (ou de ses dirigeants) pour tromper ses interlocuteurs. Elle recouvre les techniques détaillées ci-dessous.

2.4 Le typosquatting et les attaques par homographe

Le **typosquatting** est l'enregistrement d'un nom de domaine proche d'un domaine légitime pour tromper les internautes. Variantes courantes, illustrées sur `cybernova.fr` :

Technique	Principe	Exemple
Omission	Une lettre supprimée	`cybernva.fr`
Permutation	Deux lettres inversées	`cybernvoa.fr`
Ajout de tiret	Séparation du nom	`cyber-nova.fr`
Substitution	Lettre proche au clavier	`cybernoba.fr`

Autre extension	Même nom, extension différente	`cybernova.com`, `cybernova.co`
Ajout de mot	Terme rassurant accolé	`cybernova-support.fr`
Homographe (IDN)	Caractère d'un autre alphabet visuellement identique	un `a` cyrillique à la place du `a` latin
Sous-domaine trompeur	Le nom réel est ailleurs dans l'adresse	`cybernova.fr.paiement-secure.example`

> **Lire une adresse de droite à gauche**
> Le domaine réel se lit de droite à gauche, avant le premier `/`. Dans `cybernova.fr.paiement-secure.example`, le domaine réel est `paiement-secure.example` et non `cybernova.fr`.

2.5 Le spoofing et le phishing ciblé

Le **spoofing d'e-mail** consiste à falsifier l'expéditeur affiché d'un message. Le protocole SMTP historique ne vérifie pas, par lui-même, que l'expéditeur est légitime : sans SPF, DKIM et DMARC (séance 3), un tiers peut envoyer un message qui semble venir de `direction@cybernova.fr`.

Forme de phishing	Cible	Caractéristique
Phishing de masse	Large public	Message générique, peu personnalisé
Spear phishing	Une personne ou un service	Message personnalisé avec des informations réelles sur la cible
Whaling	Dirigeants	Cible à fort pouvoir de décision ou de paiement
Fraude au président	Service financier	Pression hiérarchique, urgence, confidentialité
Fraude au faux fournisseur	Comptabilité	Changement de coordonnées bancaires d'un fournisseur réel

Indices à rechercher : domaine d'expéditeur différent du domaine officiel, urgence ou menace, demande inhabituelle de paiement ou de données, adresse de réponse (`Reply-To`) différente de l'expéditeur, lien dont la destination réelle diffère du texte affiché, pièce jointe inattendue.

2.6 Faux comptes, vol de comptes, défiguration et e-réputation

- **Faux compte** : profil créé de toutes pièces avec le logo et le nom de l'organisation.
- **Vol de compte** : prise de contrôle du compte réel (mot de passe réutilisé ou faible, absence de MFA, hameçonnage).
- **Fausse application mobile** : application publiée sous un nom proche sur une boutique d'applications.
- **Défiguration (defacement)** : modification non autorisée du contenu d'un site *réel*. À distinguer du typosquatting, qui crée un site *imitateur*. Elle révèle souvent une vulnérabilité (CMS non mis à jour, mot de passe d'administration faible).
- **Atteinte à l'e-réputation** : faux avis en masse, campagnes de dénigrement, rumeurs relayées par de faux comptes, sans aucune intrusion technique.

2.7 Dimension juridique : usurpation, diffamation, dénigrement

Notion	Explication	Exemple
Usurpation d'identité	Utilisation frauduleuse de l'identité ou de données permettant d'identifier un tiers	Faux message envoyé au nom du dirigeant
Diffamation	Imputation d'un fait précis portant atteinte à l'honneur ou à la considération d'une personne physique ou morale	Accusation factuelle publiée contre l'entreprise
Dénigrement	Critique de produits ou services susceptible de nuire aux intérêts économiques d'une entreprise	Affirmations dévalorisantes sur un service commercial
Accès ou maintien frauduleux	Intrusion dans un système sans autorisation	Défiguration après intrusion

Point de vigilance juridique

Ces qualifications ne sont **pas automatiques** : elles dépendent du contenu, du contexte et du droit applicable. Les sanctions et délais de prescription (très courts pour certaines infractions de presse) sont à vérifier dans les textes en vigueur avant d'être invoqués. Ne les citez pas de mémoire à l'examen sans la source fournie par le dossier.

2.8 Conséquences économiques et risque humain

- Indisponibilité d'un site ou d'un service, interruption de production, retards de livraison, perte de chiffre d'affaires.
- Vol de données personnelles ou d'informations stratégiques ; infection par logiciel malveillant ou rançongiciel diffusé via un faux site ou un compte compromis.
- Perte de confiance des clients et partenaires ; frais d'investigation, de restauration, de communication de crise et de conseil juridique.
- Pour les organisations dont l'activité a des conséquences physiques (produits dangereux, énergie, eau, santé) : sécurité des personnes, continuité des opérations, disponibilité des systèmes de contrôle, environnement.

Les baromètres sectoriels (par exemple celui du CESIN) donnent des ordres de grandeur sur la fréquence du phishing, de la fraude au président ou de l'usurpation d'identité. Ces chiffres évoluent chaque année : présentez-les **toujours avec leur année et leur source**.

2.9 Scénario d'attaque type (kill chain simplifiée)

1. Reconnaissance	2. Préparation	3. Diffusion	4. Exploitation	5. Monétisation
informations publiques : organigramme, fournisseurs, e-mails	domaine proche, certificat, copie du site, faux compte	e-mails, SMS, messageries, réseaux sociaux	identifiants saisis, fausse facture payée, fichier ouvert	virement, revente de données, réutilisation

Point clé : l'organisation victime n'est souvent alertée qu'à l'étape 4 ou 5, par un client ou un partenaire. D'où l'intérêt d'une surveillance en amont (séance 3).

Atelier Kali K2 — Analyser un message et un domaine suspects (40 min)

Contexte : le service sécurité de CyberNova a reçu un e-mail signalé par une salariée. Il a été enregistré dans le fichier `suspect.eml` du dossier de travail. Vous l'analysez **sans cliquer sur aucun lien**, dans le laboratoire isolé.

Exercice K2.1 — Examiner les en-têtes

K2.1 — En-têtes du message suspect — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ ls -l suspect.eml
-rw-r--r-- 1 kali kali 3187 Oct 23 09:41 suspect.eml
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ sha256sum suspect.eml | tee preuve-suspect.sha256
9c1f4ab27e0d58c6b13f7a02d9e4a65f4c10b8d27a3e91f06c5b7d2e48a1f3c0  suspect.eml
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ grep -E "^(From|Reply-To|Return-Path|Received|Authentication-Results|Subject|Date):" suspect
.eml
From: "Service Facturation CyberNova" <facturation@cyber-nova.fr>
Reply-To: paiements@mail-secure.example
Return-Path: <bounce@srv12.hosting.example>
Received: from srv12.hosting.example (203.0.113.77) by mx.cybernova.fr; Fri, 23 Oct 2026
07:12:44 +0200
Authentication-Results: mx.cybernova.fr; spf=fail smtp.mailfrom=cyber-nova.fr; dkim=none;
dmarc=fail header.from=cyber-nova.fr
Subject: URGENT - Facture impayée, règlement sous 24 h
Date: Fri, 23 Oct 2026 07:12:40 +0200
```

Signification des lignes de commande

Commande ou ligne	Signification
`ls -l suspect.eml`	Liste le fichier avec ses droits, sa taille et sa date : vérification que le message à analyser est bien présent.
`sha256sum suspect.eml | tee preuve-suspect.sha256`	`sha256sum` calcule l'empreinte SHA-256 du fichier. `tee` l'affiche et l'enregistre en même temps dans `preuve-suspect.sha256`. À faire avant toute analyse : l'empreinte prouvera que le fichier n'a pas changé.
`grep -E "^(From|Reply-To|Return-Path|Received|Authentication-Results|Subject|Date):" suspect.eml`	`grep -E` utilise une expression régulière étendue. `^` = début de ligne ; `(A|B|…)` = l'un ou l'autre des champs ; `:` = fin du nom du champ. On n'extrait que les en-têtes utiles à l'analyse : expéditeur, adresse de réponse, chemin du message, résultats SPF/DKIM/DMARC, sujet, date.

Questions. (1) Quels éléments sont incohérents ? (2) Quel élément de l'identité est imité ? (3) Que révèlent `spf=fail`, `dkim=none` et `dmarc=fail` ? (4) Pourquoi calcule-t-on l'empreinte SHA-256 avant toute autre action ?

Exercice K2.2 — Extraire les liens sans les ouvrir

K2.2 — Liens du message (sans les visiter) — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ grep -oE "https?://[^\"' <>]+" suspect.eml | sort -u
https://cyber-nova.fr/facture/ref-20261023
https://cybernova.fr.paiement-secure.example/login
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ grep -oE "https?://[^\"' <>]+" suspect.eml | sed -E 's#https?://([^/]+).*#\1#' | sort -u
cyber-nova.fr
cybernova.fr.paiement-secure.example
```

Signification des lignes de commande

Commande ou ligne	Signification
`grep -oE "https?://[^\"' <>]+" suspect.eml | sort -u`	`-o` n'affiche que la partie qui correspond au motif ; `https?://` reconnaît http ou https ; `[^"' <>]+` prend tous les caractères jusqu'au premier guillemet, espace ou chevron. `sort -u` trie et supprime les doublons. Aucun lien n'est ouvert : on se contente de les lire.
`… | sed -E 's#https?://([^/]+).*#\1#' | sort -u`	`sed -E` remplace chaque adresse par son seul nom d'hôte : `#` sert de séparateur, `([^/]+)` capture ce qui précède le premier `/`, `\1` réinsère cette capture. On obtient la liste des domaines réellement visés.

Questions. (5) Quel est le domaine réel du second lien ? (6) Pourquoi ne faut-il pas ouvrir ces liens depuis un poste de production ?

Exercice K2.3 — Identifier les domaines imitateurs

`dnstwist` génère des variantes d'un domaine et teste lesquelles sont enregistrées. Ici, on cible le domaine du laboratoire.

K2.3 — Variantes enregistrées du domaine — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dnstwist --registered cybernova.fr
dnstwist 20250130 by marcin@ulikowski.pl
Processing 142 permutations 100% |████████████████████████████████| 142/142
*original      cybernova.fr     203.0.113.10  NS:ns1.cybernova.fr MX:mail.cybernova.fr
addition       cybernovas.fr    198.51.100.21     NS:ns1.parkdns.example
hyphenation    cyber-nova.fr     203.0.113.77   NS:ns.hosting.example MX:mail.cyber-nova.fr
omission       cybernva.fr      198.51.100.34     NS:ns1.parkdns.example
tld-swap       cybernova.com    198.51.100.60     NS:ns1.registrar.example
various        cybernova-support.fr 203.0.113.77 NS:ns.hosting.example
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dnstwist --registered --format csv cybernova.fr > variantes.csv
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ wc -l variantes.csv
```

```
7 variantes.csv
```

Signification des lignes de commande

Commande ou ligne	Signification
`dnstwist --registered cybernova.fr`	`dnstwist` génère des variantes typographiques du domaine (omissions, permutations, tirets, autres extensions…) et teste leur résolution DNS. `--registered` n'affiche que celles qui existent. Les colonnes donnent le type de variante, le domaine, l'adresse IP, le serveur DNS et le serveur de messagerie.
`dnstwist --registered --format csv cybernova.fr > variantes.csv`	`--format csv` produit un tableau exploitable ; `>` redirige la sortie vers le fichier `variantes.csv` au lieu de l'écran.
`wc -l variantes.csv`	`wc -l` compte les lignes : 7 = l'en-tête, l'original et 5 variantes enregistrées.

Questions. (7) Quelles variantes présentent un risque élevé et pourquoi ? (8) Que signifie le fait que `cyber-nova.fr` et `cybernova-support.fr` partagent la même adresse IP ?

Exercice K2.4 — Consulter les informations d'enregistrement

K2.4 — Informations publiques d'enregistrement (lab) — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ whois cyber-nova.fr | grep -iE "domain|created|registrar|expiry|status|holder"
domain:                 cyber-nova.fr
status:                 ACTIVE
holder-c:               ANO00-FRNIC
registrar:              Hosting Registrar Example
Expiry Date:            2027-10-18T07:58:12Z
created:                2026-10-19T07:58:12Z
```

Signification des lignes de commande

Commande ou ligne	Signification
`whois cyber-nova.fr | grep -iE "domain|created|registrar|expiry|status|holder"`	`whois` interroge la base publique d'enregistrement du domaine. `grep -iE` filtre sans tenir compte de la casse (`-i`) sur les champs utiles : nom, date de création, bureau d'enregistrement, expiration, statut, titulaire. La date de création récente est un indice fort.

Questions. (9) Pourquoi la date de création est-elle un indice important ? (10) Que peut-on conclure de l'anonymisation du titulaire ?

> **Ne visitez pas le site imitateur depuis un poste de production**
>
> Un domaine imitateur peut héberger du contenu malveillant. Si une capture est nécessaire, elle se fait dans le laboratoire isolé, avec date et heure visibles, et sans saisir aucune donnée.

2.10 Exercice d'application : tableau des menaces (livrable)

À partir du cas CyberNova, complétez le tableau (une ligne par menace identifiée), puis calculez la criticité (**gravité × probabilité**, chacune de 1 à 4) et classez les menaces par priorité, comme dans la méthode du Thème 1.

Menace	Composant visé	Indice observable	Conséquence	G	P	Criticité
Typosquatting `cyber-nova.fr`	Nom de domaine	Domaine proche dans un e-mail suspect	Vol d'identifiants clients			
Faux compte LinkedIn	Compte officiel, marque	Logo copié	Faux recrutement, perte de confiance			
Spoofing de l'expéditeur	Messagerie	Échec SPF et DMARC	Fraude au faux fournisseur			
Prise de contrôle du compte officiel	Compte officiel	Aucun responsable identifié	Publication frauduleuse			

Corrigés de la séance 2

K2.1. (1) Domaine d'expéditeur `cyber-nova.fr` différent du domaine officiel ; `Reply-To` sur un troisième domaine ; `Return-Path` et serveur d'envoi sans rapport avec CyberNova ; sujet urgent et menaçant. (2) Le nom de domaine et la marque (nom d'affichage « Service Facturation CyberNova »). (3) Le serveur d'envoi n'est pas autorisé par le domaine (SPF), le message n'est pas signé (DKIM) et il échoue à l'alignement DMARC : l'authenticité n'est pas démontrée. (4) L'empreinte prouve que le fichier n'a pas été modifié depuis le recueil : c'est la base de l'intégrité de la preuve.

K2.2. (5) `paiement-secure.example` : on lit de droite à gauche, le nom `cybernova.fr` n'est qu'un sous-domaine. (6) Le site peut exploiter une faille du navigateur, livrer un logiciel malveillant ou tracer la visite ; l'analyse se fait en environnement isolé.

K2.3. (7) `cyber-nova.fr` (MX actif : peut envoyer et recevoir du courrier, déjà vu dans le message suspect) et `cybernova-support.fr` (même hébergeur et même IP : même infrastructure). Les autres sont du stationnement (« parking ») ou des extensions, risque à surveiller mais moindre. (8) Les deux domaines sont très probablement gérés par la même personne : à regrouper dans le signalement.

K2.4. (9) Un domaine créé quatre jours avant l'attaque correspond au schéma classique : enregistrement récent, utilisation immédiate. (10) L'anonymisation est fréquente et légale ; elle ne prouve rien, mais empêche l'identification directe et impose de passer par le registrar et l'hébergeur.

Tableau des menaces (exemple). Typosquatting : G3 × P4 = 12 ; spoofing : G3 × P4 = 12 ; prise de contrôle du compte officiel : G4 × P2 = 8 ; faux compte LinkedIn : G2 × P3 = 6. Priorité : traiter d'abord le domaine et le spoofing, puis sécuriser le compte officiel.

2.11 Synthèse à retenir

Notion	À savoir expliquer
Typosquatting	Domaine proche enregistré pour tromper
Homographe	Caractères visuellement identiques d'un autre alphabet

Spoofing	Falsification de l'expéditeur d'un message
Spear phishing	Hameçonnage personnalisé pour une cible précise
Défiguration	Modification non autorisée d'un site réel
Atteinte à l'e-réputation	Publication nuisant à la confiance du public
Diffamation / dénigrement	Qualifications juridiques distinctes, non automatiques

La séance 3 répond à la question : comment rendre ces attaques plus difficiles, et comment les détecter plus tôt ?

Séance 3 — Les mesures de protection

Durée : 2 h · Atelier Kali K3 · Livrable : plan de protection de l'identité numérique de CyberNova

3.1 Objectifs pédagogiques

- Expliquer le rôle de SPF, DKIM et DMARC et lire leurs enregistrements.
- Décrire l'apport de DNSSEC et ses limites.
- Gérer le cycle de vie des certificats et comprendre la transparence des certificats.
- Sécuriser les comptes officiels et les accès administrateurs.
- Mettre en place une surveillance de marque et de domaines.
- Choisir des mesures proportionnées au risque, en tenant compte de leur coût.

3.2 Logique de défense : prévenir, détecter, réagir

Aucune mesure ne suffit seule. On applique la **défense en profondeur**, déjà vue au Thème 1 : plusieurs couches complémentaires, de sorte que la défaillance d'une seule ne compromette pas l'ensemble.

Couche	Objectif	Mesures de la séance
Prévenir	Rendre l'usurpation difficile	Verrouillage et réservation de domaines, SPF/DKIM/DMARC, DNSSEC, CAA, MFA
Détecter	Repérer vite une imitation ou un abus	Surveillance de marque, rapports DMARC, transparence des certificats
Réagir	Limiter les dégâts	Procédure de signalement et de preuves (séance 5)

3.3 Protéger le nom de domaine

- **Verrou d'enregistrement** : activer le verrouillage du transfert et de la modification chez le bureau d'enregistrement (registrar).
- **Comptes du registrar** : MFA obligatoire, adresse de récupération dédiée, au moins deux administrateurs identifiés.
- **Renouvellement** automatique et alertes d'échéance : un domaine expiré peut être racheté par un tiers et réutilisé contre l'organisation.
- **Réservation défensive** des extensions et variantes les plus probables, en proportion du risque et du budget.
- **Inventaire** de tous les domaines, sous-domaines et prestataires DNS. Un sous-domaine oublié pointant vers un service décommissionné peut être repris par un tiers (subdomain takeover).

3.4 Protéger la messagerie : SPF, DKIM, DMARC

Ces trois mécanismes répondent au problème du spoofing : empêcher un tiers d'envoyer des messages se présentant comme issus de votre domaine.

Mécanisme	Question à laquelle il répond	Principe
SPF (Sender Policy Framework)	Ce serveur est-il autorisé à envoyer du courrier pour ce domaine ?	Le domaine publie en TXT la liste des serveurs autorisés
DKIM (DomainKeys Identified Mail)	Le message a-t-il été signé par le domaine et reste-t-il intact ?	Le serveur signe le message ; la clé publique est publiée en TXT
DMARC (Domain-based Message Authentication, Reporting and Conformance)	Que faire d'un message qui échoue, et comment en être informé ?	Politique publiée en TXT, alignement du domaine affiché, rapports

Exemples d'enregistrements (domaine fictif) — kali@kali

```
┌──(kali㉿kali)-[~]
└─$ cat zone-extrait.txt
cybernova.fr.                    TXT  "v=spf1 mx include:_spf.mailprovider.example -all"
selector1._domainkey.cybernova.fr. TXT  "v=DKIM1; k=rsa; p=MIIBIjANBgkq..."
_dmarc.cybernova.fr.             TXT  "v=DMARC1; p=quarantine; rua=mailto:dmarc@cybernova.fr;
adkim=s; aspf=s"
```

Signification des lignes de commande

Commande ou ligne	Signification
`cat zone-extrait.txt`	`cat` affiche le fichier contenant trois enregistrements TXT à lire :
`cybernova.fr. TXT "v=spf1 mx include:_spf.mailprovider.example -all"`	**SPF** : `mx` autorise les serveurs MX du domaine ; `include:` autorise aussi ceux du prestataire de messagerie ; `-all` demande de rejeter tout autre serveur.
`selector1._domainkey.cybernova.fr. TXT "v=DKIM1; k=rsa; p=…"`	**DKIM** : `selector1` identifie la clé ; `k=rsa` l'algorithme ; `p=` contient la clé publique qui sert à vérifier la signature des messages.
`_dmarc.cybernova.fr. TXT "v=DMARC1; p=quarantine; rua=…; adkim=s; aspf=s"`	**DMARC** : `p=quarantine` met en quarantaine les messages en échec ; `rua` reçoit les rapports agrégés ; `adkim=s` et `aspf=s` imposent un alignement strict du domaine.

Élément	Lecture
SPF `-all`	Les serveurs MX et ceux du prestataire sont autorisés ; tout autre serveur doit être rejeté (`~all` : échec « doux », plus tolérant).
DKIM `selector1`, `p=`	Le sélecteur identifie la clé ; `p=` contient la clé publique qui permet de vérifier la signature.
DMARC `p=quarantine`	Les messages en échec sont placés en quarantaine ; `rua` reçoit les rapports agrégés ; `adkim=s` et `aspf=s` imposent un alignement strict.

Valeur de `p`	Effet	Usage
`none`	Aucune action, rapports seulement	Phase d'observation

`quarantine`	Messages en échec placés en spam	Phase intermédiaire
`reject`	Messages en échec refusés	Protection maximale

1. Inventorier
tous les services qui envoient au nom du domaine

2. SPF + DKIM
publier et vérifier

3. DMARC p=none
avec adresse de rapports

4. Analyser
les rapports, corriger les expéditeurs légitimes

5. Durcir
quarantine puis reject

Limites

SPF peut casser lors d'un transfert de message. DKIM ne dit rien de l'honnêteté de l'expéditeur. DMARC ne protège que **votre** domaine : il n'empêche pas l'enregistrement de `cyber-nova.fr`, d'où la nécessité de la surveillance de marque. Passer directement à `reject` sans observation risque de bloquer du courrier légitime.

3.5 DNSSEC et CAA

DNSSEC ajoute des signatures cryptographiques aux enregistrements DNS : un résolveur compatible peut vérifier que la réponse provient de la zone légitime et n'a pas été falsifiée (empoisonnement de cache, détournement de réponses). Il garantit l'**authenticité et l'intégrité** des réponses DNS, pas leur confidentialité, et ne dit rien de l'honnêteté du propriétaire : `cyber-nova.fr` peut être parfaitement signé. Une erreur de gestion des clés peut rendre le domaine injoignable.

Un enregistrement **CAA** limite les autorités de certification autorisées à émettre des certificats pour votre domaine.

3.6 Gérer les certificats

- **Inventaire** de tous les certificats avec date d'expiration et responsable.
- **Renouvellement automatisé** quand c'est possible, supervision des échéances avec alertes : un certificat expiré provoque une alerte navigateur et peut interrompre un service.
- **Protection des clés privées** : stockage sécurisé, accès restreint, remplacement immédiat en cas de compromission avec **révocation** du certificat.
- **Transparence des certificats** (Certificate Transparency) : les autorités publient les certificats émis dans des journaux publics. Les surveiller permet de détecter un certificat émis pour votre domaine ou une variante proche sans que vous l'ayez demandé.

3.7 Sécuriser les comptes officiels

Mesure	Objectif
Authentification multifacteur (MFA)	Rendre le vol de mot de passe insuffisant
Gestionnaire de mots de passe, mots de passe uniques et longs	Éviter la réutilisation et les mots de passe faibles

Principe du moindre privilège	Limiter le nombre d'administrateurs et leurs droits
Inventaire des comptes et des responsables	Savoir qui détient quoi, y compris après un départ
Comptes nominatifs plutôt que partagés	Garantir la traçabilité
Procédure de récupération	Reprendre un compte compromis rapidement
Vérification des comptes officiels (badge, lien depuis le site officiel)	Aider le public à distinguer le vrai du faux

Pour les comptes d'administration, préférez une MFA résistante à l'hameçonnage (clé de sécurité physique, passkey) à un code reçu par SMS, qui reste vulnérable à l'interception ou à l'ingénierie sociale.

3.8 Surveiller la marque et les domaines

Source de veille	Ce qu'elle permet de détecter
Nouveaux domaines ressemblant au nom	Typosquatting, homographes
Journaux de transparence des certificats	Certificats émis pour des variantes du nom
Rapports DMARC agrégés	Serveurs tiers envoyant du courrier sous votre domaine
Réseaux sociaux et boutiques d'applications	Faux comptes, fausses applications
Moteurs de recherche, avis en ligne	Faux sites, faux avis, contenus de dénigrement

Sensibilisation. Les protections techniques n'arrêtent pas toutes les attaques. Prévoir une formation régulière aux indices de phishing, un canal de signalement simple, des exercices de simulation (Thème 3) et une règle de **contre-vérification** : toute demande de virement ou de changement de coordonnées bancaires est confirmée par un second canal connu.

3.9 Évaluer le risque et choisir les mesures

1. Identifier les actifs et services essentiels (domaine, messagerie, compte LinkedIn, site de paiement).
2. Décrire les scénarios de menace (séance 2).
3. Estimer probabilité et gravité de chaque scénario.
4. Calculer la criticité (probabilité × gravité) et comparer le coût de la mesure à la perte potentielle.
5. Décider pour chaque risque : **réduire**, **accepter** (risque résiduel documenté), **transférer** en partie (assurance) ou **éviter**.

La **cyberassurance** peut couvrir certains coûts (investigation, restauration, notification, communication de crise, pertes d'exploitation) selon les garanties, exclusions, franchises et conditions du contrat. Elle ne remplace ni la prévention, ni la sauvegarde, ni la gestion d'incident, et l'assureur peut exiger des mesures minimales (MFA, sauvegardes).

Atelier Kali K3 — Vérifier les protections d'un domaine (40 min)

Objectif : contrôler depuis Kali la présence et la qualité de SPF, DKIM, DMARC, CAA et DNSSEC. Cible : `lab.cybernova.test` (simulation).

Exercice K3.1 — Auditer SPF et DMARC

K3.1 — SPF et DMARC — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test TXT +short | grep spf1
"v=spf1 mx include:_spf.mailprovider.example -all"
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig _dmarc.lab.cybernova.test TXT +short
(aucune réponse)
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig _dmarc.example.com TXT +short
"v=DMARC1; p=reject; rua=mailto:dmarc-reports@example.com; adkim=s; aspf=s"
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig selector1._domainkey.lab.cybernova.test TXT +short
"v=DKIM1; k=rsa; p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA..."
```

Signification des lignes de commande

Commande ou ligne	Signification
`dig lab.cybernova.test TXT +short | grep spf1`	Récupère les TXT du domaine et ne garde que la ligne SPF. Ici elle se termine par `-all` : politique stricte.
`dig _dmarc.lab.cybernova.test TXT +short`	La politique DMARC est publiée sous le nom spécial `_dmarc.` suivi du domaine. **Aucune réponse** = pas de DMARC publié : constat à reporter dans le rapport.
`dig _dmarc.example.com TXT +short`	Même requête sur un domaine bien configuré, pour comparer. `p=reject` : rejet des messages en échec ; `rua` : adresse des rapports.
`dig selector1._domainkey.lab.cybernova.test TXT +short`	La clé publique DKIM se publie sous `sélecteur._domainkey.domaine`. Il faut connaître le sélecteur (visible dans l'en-tête `DKIM-Signature` d'un message reçu).

Questions. (1) Que manque-t-il à `lab.cybernova.test` pour se protéger du spoofing ? (2) Que se passe-t-il aujourd'hui pour un message envoyé par un tiers au nom de `@lab.cybernova.test` ? (3) Pourquoi la clé DKIM publique peut-elle être visible de tous ?

Exercice K3.2 — CAA et DNSSEC

K3.2 — CAA et DNSSEC — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test CAA +short
0 issue "lab-ca.cybernova.test"
0 iodef "mailto:securite@lab.cybernova.test"
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig lab.cybernova.test DNSKEY +short
(aucune réponse : DNSSEC non activé sur la zone de laboratoire)
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ dig example.com A +dnssec +noall +answer +comments
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
example.com.            300     IN      A       198.51.100.50
```

```
example.com.            300     IN      RRSIG       A 13 2 300 20261110000000 20261020000000
12345 example.com. mFq3...fictif
```

Signification des lignes de commande

Commande ou ligne	Signification
`dig lab.cybernova.test CAA +short`	Affiche les enregistrements CAA : `issue` désigne la seule autorité autorisée à émettre des certificats pour le domaine ; `iodef` donne l'adresse où signaler une demande suspecte.
`dig lab.cybernova.test DNSKEY +short`	Cherche les clés publiques DNSSEC de la zone. Aucune réponse = DNSSEC non activé sur ce domaine.
`dig example.com A +dnssec +noall +answer +comments`	`+dnssec` demande aussi les signatures ; `+comments` garde les lignes de commentaire (dont les drapeaux). Le drapeau `ad` (authenticated data) indique que le résolveur a validé les signatures. La ligne `RRSIG` est la signature de l'enregistrement A.

Questions. (4) Que limite l'enregistrement CAA ? (5) Que signifie le drapeau `ad` et la présence d'un `RRSIG` ? (6) DNSSEC activé suffit-il à prouver qu'un site est honnête ?

Exercice K3.3 — Surveiller la transparence des certificats

Les journaux publics recensent les certificats émis. Une requête sur le domaine permet d'y repérer un certificat inattendu.

K3.3 — Certificats émis pour le domaine (simulation) — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ curl -s "https://crt.sh/?q=%25.cybernova.fr&output=json" | jq -r '.[] |
[.not_before, .common_name, .issuer_name] | @tsv' | sort -r | head -5
2026-10-20T06:41:09     cyber-nova.fr        C=US, O=Let's Encrypt, CN=R11
2026-09-14T09:02:11     www.cybernova.fr        C=US, O=Let's Encrypt, CN=R11
2026-09-14T09:02:11     cybernova.fr        C=US, O=Let's Encrypt, CN=R11
2026-06-02T13:20:45     paiement.cybernova.fr        C=US, O=Let's Encrypt, CN=R11
2026-03-15T08:10:30     mail.cybernova.fr        C=US, O=Let's Encrypt, CN=R11
```

Signification des lignes de commande

Commande ou ligne	Signification
`curl -s "https://crt.sh/?q=%25.cybernova.fr&output=json"`	`curl -s` télécharge sans affichage de progression. L'adresse interroge un service public qui recense les journaux de transparence des certificats : `%25` est le caractère `%` encodé (joker : tous les noms de `cybernova.fr`) et `output=json` demande un résultat structuré.
`… | jq -r '.[] | [.not_before, .common_name, .issuer_name] | @tsv'`	`jq` lit le JSON : `.[]` parcourt chaque certificat, les crochets extraient trois champs (date de début, nom, émetteur), `@tsv` les met en colonnes séparées par des tabulations ; `-r` supprime les guillemets.
`… | sort -r | head -5`	`sort -r` trie en ordre décroissant (les dates ISO les plus récentes en premier) ; `head -5` garde les cinq premières lignes. Un nom inattendu récent, comme `cyber-nova.fr`, est un signal à examiner.

Questions. (7) Quelle ligne est suspecte et pourquoi ? (8) Cela prouve-t-il que l'attaquant a compromis CyberNova ? (9) Quelle mesure transformerait cette découverte en alerte automatique ?

Exercice K3.4 — Générer un enregistrement DMARC de départ

K3.4 — Préparer la politique DMARC — kali@kali

```
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ echo
'_dmarc.cybernova.fr.  3600  IN  TXT  "v=DMARC1; p=none; rua=mailto:dmarc@cybernova.fr; fo=1"'
> dmarc-etape1.txt
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ cat dmarc-etape1.txt
_dmarc.cybernova.fr.  3600  IN  TXT  "v=DMARC1; p=none; rua=mailto:dmarc@cybernova.fr; fo=1"
┌──(kali㉿kali)-[~/identite-numerique/2026-10-23]
└─$ wc -c dmarc-etape1.txt
93 dmarc-etape1.txt
```

Signification des lignes de commande

Commande ou ligne	Signification
`echo '_dmarc.cybernova.fr. 3600 IN TXT "v=DMARC1; p=none; …"' > dmarc-etape1.txt`	`echo` écrit la ligne entre apostrophes (qui protègent les guillemets) ; `>` la place dans le fichier. L'enregistrement commence en mode observation : `p=none`, avec `rua` pour les rapports et `fo=1` pour demander des rapports d'échec détaillés.
`cat dmarc-etape1.txt`	Relit le fichier pour vérifier son contenu avant de le publier chez l'hébergeur DNS.
`wc -c dmarc-etape1.txt`	`wc -c` compte les octets du fichier (93, retour à la ligne compris) ; contrôle rapide qu'il n'a pas été tronqué.

Questions. (10) Pourquoi commencer par `p=none` ? (11) Quelle est la prochaine étape après quelques semaines de rapports ?

3.10 Exercice : plan de protection CyberNova (livrable)

CyberNova (40 salariés, vente de services en ligne) souhaite se protéger après l'affaire `cyber-nova.fr`. Établissez un plan de protection priorisé.

Priorité	Mesure	Risque traité	Coût (faible / moyen / élevé)	Délai	Responsable
1					
2					
3					

Corrigés de la séance 3

K3.1. (1) Une politique DMARC : aucun enregistrement `_dmarc` n'est publié. (2) Le serveur de réception peut vérifier SPF seul, sans instruction de rejet ou de quarantaine : l'usurpation peut aboutir selon la configuration du destinataire. (3) Elle sert uniquement à **vérifier** la signature ; la clé privée, qui permet de signer, reste secrète sur le serveur d'envoi.

K3.2. (4) Les autorités autorisées à émettre des certificats pour le domaine (`issue`), et l'adresse de signalement des incidents (`iodef`). (5) `ad` (authenticated data) : le résolveur a validé les signatures ; `RRSIG` est la signature de l'enregistrement. (6) Non : DNSSEC authentifie les réponses DNS, pas l'honnêteté du propriétaire.

K3.3. (7) Le certificat de `cyber-nova.fr` , émis le 20 octobre 2026 pour un nom que CyberNova n'exploite pas. (8) Non : il prouve que quelqu'un a obtenu un certificat pour un domaine proche, comme n'importe quel site. (9) Une surveillance automatique des journaux de transparence avec alerte sur les noms proches.

K3.4. (10) Pour observer qui envoie du courrier au nom du domaine sans rien bloquer, afin d'identifier d'abord les expéditeurs légitimes. (11) Corriger SPF/DKIM des expéditeurs légitimes manquants, puis passer à `quarantine` avec un pourcentage progressif, puis à `reject` .

Plan de protection (éléments attendus). Priorité 1 : MFA et inventaire des administrateurs des comptes officiels et du registrar (coût faible, effet fort) ; priorité 2 : SPF, DKIM et DMARC en `p=none` puis durcissement ; priorité 3 : surveillance des domaines proches et des certificats, réservation défensive, procédure de contre-vérification des virements. Toute proposition est justifiée par un risque identifié et un bénéfice attendu.

3.11 Synthèse à retenir

Notion	À savoir expliquer
SPF	Liste des serveurs autorisés à envoyer pour le domaine
DKIM	Signature cryptographique des messages
DMARC	Politique en cas d'échec, alignement et rapports
DNSSEC	Signature des réponses DNS (authenticité, intégrité)
CAA	Limite des autorités autorisées à émettre des certificats
Certificate Transparency	Journaux publics des certificats émis
MFA	Second facteur d'authentification, idéalement résistant à l'hameçonnage
Surveillance de marque	Détection d'imitations avant les premières victimes

Séance 4 — Atelier Kali : audit d'identité numérique

Durée : 2 h · Atelier pratique en environnement virtuel isolé · Livrable : rapport d'audit d'identité numérique avec recommandations

4.1 Objectifs pédagogiques

- Conduire un audit **passif** de l'identité numérique d'un domaine dont on est propriétaire ou autorisé.
- Utiliser `dig`, `dnsrecon`, `dnstwist`, `sslscan`, `testssl.sh`, `curl` et `theHarvester` et interpréter leurs résultats.
- Rédiger un rapport factuel : constats, niveau de risque, recommandations priorisées.

4.2 Cadre légal et déontologique

À lire et à signer avant toute manipulation

- **Périmètre écrit** : l'audit ne porte que sur les domaines et systèmes expressément autorisés. Pour l'atelier : le domaine de laboratoire `lab.cybernova.test` fourni par le formateur, ou `example.com` en consultation passive.
- **Autorisation** : toute action sur un système appartenant à un tiers sans autorisation écrite peut constituer une infraction pénale (accès frauduleux, atteinte au fonctionnement d'un système, articles 323-1 et suivants du Code pénal).
- **Environnement isolé** : les outils sont lancés depuis la machine Kali virtuelle du laboratoire. Aucun scan intrusif vers Internet.
- **Proportionnalité** : techniques passives ou non intrusives uniquement (requêtes DNS standard, une seule connexion TLS). Pas de test de charge, pas de force brute.
- **Données personnelles** : les adresses e-mail et noms collectés sont des données personnelles. Limitez-les au strict nécessaire, protégez-les et supprimez-les en fin d'atelier (RGPD, Thème 1).
- **Traçabilité** : notez la date, l'heure, la machine source et les commandes utilisées.

4.3 Déroulé de l'atelier (2 h)

Horaire	Activité
0 h 00 – 0 h 15	Rappel du cadre légal, signature de la charte d'atelier, mise en place du dossier de preuves
0 h 15 – 0 h 40	Étape 1 : cartographie DNS
0 h 40 – 0 h 55	Étape 2 : domaines imitateurs
0 h 55 – 1 h 15	Étape 3 : certificat et configuration TLS

1 h 15 – 1 h 25	Étape 4 : en-têtes HTTP de sécurité
1 h 25 – 1 h 35	Étape 5 : exposition publique (laboratoire uniquement)
1 h 35 – 2 h 00	Étape 6 : synthèse, empreintes, début du rapport (à terminer en autonomie)

4.4 Étape 0 — Préparer le dossier de travail et la traçabilité

Chaque sortie d'outil est conservée dans un fichier horodaté. Une trace de session permet de prouver ce qui a été exécuté.

K4.0 — Dossier d'audit et journal de session — kali@kali

```
┌──(kali㉿kali)-[~]
└─$ export CIBLE=lab.cybernova.test
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/audit-identite/$(date +%F) && cd ~/audit-identite/$(date +%F)
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ script -q -a journal-session.txt
Script started, output log file is 'journal-session.txt'.
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ date -Is && hostname && echo "Périmètre : $CIBLE (autorisé par le formateur)" | tee perimetre.txt
2026-10-23T09:47:12+02:00
kali
Périmètre : lab.cybernova.test (autorisé par le formateur)
```

Signification des lignes de commande

Commande ou ligne	Signification
`export CIBLE=lab.cybernova.test`	Crée une variable d'environnement : `$CIBLE` peut ensuite être réutilisé dans toutes les commandes, ce qui évite les erreurs de frappe et limite l'audit au périmètre autorisé.
`mkdir -p … && cd …`	Crée le dossier d'audit du jour et s'y place (voir la console de préparation du laboratoire).
`script -q -a journal-session.txt`	`script` enregistre tout ce qui s'affiche dans le terminal. `-q` supprime les messages de début et fin ; `-a` ajoute au fichier au lieu de l'écraser. L'enregistrement s'arrête avec `exit`.
`date -Is && hostname && echo "Périmètre : $CIBLE …" | tee perimetre.txt`	`date -Is` affiche la date et l'heure au format ISO avec fuseau horaire ; `hostname` le nom de la machine ; `echo` écrit le périmètre autorisé, que `tee` affiche et enregistre dans `perimetre.txt`. Trace datée de qui audite quoi, avec quelle autorisation.

4.5 Étape 1 — Cartographier le DNS (`dig`, `dnsrecon`)

Exercice K4.1 — Relevé DNS complet

K4.1 — dnsrecon : énumération standard — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ dnsrecon -d $CIBLE -t std | tee dnsrecon-std.txt
[*] std: Performing General Enumeration against: lab.cybernova.test...
[*] DNSSEC is not configured for lab.cybernova.test
```

```
[*]         SOA ns1.lab.cybernova.test 203.0.113.2
[*]         NS ns1.lab.cybernova.test 203.0.113.2
[*]         NS ns2.lab.cybernova.test 203.0.113.3
[*]         MX mail.lab.cybernova.test 203.0.113.25
[*]         A lab.cybernova.test 203.0.113.10
[*]         TXT lab.cybernova.test v=spf1 mx include:_spf.mailprovider.example -all
[*] Enumerating SRV Records
[-] No SRV Records Found for lab.cybernova.test
```

Signification des lignes de commande

Commande ou ligne	Signification
`dnsrecon -d $CIBLE -t std | tee dnsrecon-std.txt`	`dnsrecon` est un outil d'énumération DNS. `-d` désigne le domaine ; `-t std` lance l'énumération standard (SOA, NS, MX, A, AAAA, TXT, SRV, test DNSSEC). `tee` affiche et conserve le résultat dans un fichier.
`[*] DNSSEC is not configured …`	Les lignes `[*]` sont des informations ; `[-]` signale qu'un élément n'a pas été trouvé. Ici : pas de DNSSEC, deux serveurs NS, un serveur MX, une adresse A et le SPF, pas d'enregistrement SRV.

K4.1 — dig : politiques de messagerie, CAA, DNSSEC — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ for t in NS MX TXT CAA DNSKEY; do echo "== $t =="; dig $CIBLE $t +short; done | tee dig-base.txt
== NS ==
ns1.lab.cybernova.test.
ns2.lab.cybernova.test.
== MX ==
10 mail.lab.cybernova.test.
== TXT ==
"v=spf1 mx include:_spf.mailprovider.example -all"
== CAA ==
0 issue "lab-ca.cybernova.test"
== DNSKEY ==
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ dig _dmarc.$CIBLE TXT +short | tee dmarc.txt
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ wc -c dmarc.txt
0 dmarc.txt
```

Signification des lignes de commande

Commande ou ligne	Signification
`for t in NS MX TXT CAA DNSKEY; do echo "== $t =="; dig $CIBLE $t +short; done | tee dig-base.txt`	Boucle `for` : pour chaque type d'enregistrement, `echo` affiche un séparateur, puis `dig … +short` donne la valeur. `done | tee` envoie l'ensemble dans un fichier unique, plus facile à joindre au rapport.
`dig _dmarc.$CIBLE TXT +short | tee dmarc.txt`	Interroge la politique DMARC et enregistre la réponse. Un fichier vide est lui-même une preuve de l'absence de politique.
`wc -c dmarc.txt`	Compte les octets : `0` confirme qu'aucune politique DMARC n'est publiée.

Questions. (1) Quels serveurs de noms font autorité ? Sont-ils chez un ou plusieurs prestataires ? (2) Le SPF se termine-t-il par `-all` ou `~all` ? (3) Une politique DMARC est-elle publiée ? (4) CAA est-il présent ? (5) DNSSEC est-il activé ? (6) Quels constats allez-vous inscrire dans le rapport ?

4.6 Étape 2 — Détecter des domaines imitateurs (`dnstwist`)

Exercice K4.2 — Variantes enregistrées

K4.2 — dnstwist, export CSV — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ dnstwist --registered --format csv cybernova.fr | tee variantes.csv
fuzzer,domain,dns_a,dns_aaaa,dns_mx,dns_ns
*original,cybernova.fr,203.0.113.10,,mail.cybernova.fr,ns1.cybernova.fr
hyphenation,cyber-nova.fr,203.0.113.77,,mail.cyber-nova.fr,ns.hosting.example
omission,cybernva.fr,198.51.100.34,,,ns1.parkdns.example
tld-swap,cybernova.com,198.51.100.60,,,ns1.registrar.example
various,cybernova-support.fr,203.0.113.77,,mail.cybernova-support.fr,ns.hosting.example
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ awk -F, 'NR>1 && $5!="" && $2!="cybernova.fr" {print $2" -> MX "$5}' variantes.csv
cyber-nova.fr -> MX mail.cyber-nova.fr
cybernova-support.fr -> MX mail.cybernova-support.fr
```

Signification des lignes de commande

Commande ou ligne	Signification
`dnstwist --registered --format csv cybernova.fr | tee variantes.csv`	Génère les variantes enregistrées au format CSV (colonnes : type de variante, domaine, adresses A et AAAA, serveur de messagerie, serveur DNS) et conserve le résultat.
`awk -F, 'NR>1 && $5!="" && $2!="cybernova.fr" {print $2" -> MX "$5}' variantes.csv`	`awk` traite le CSV ligne par ligne. `-F,` : séparateur virgule. Conditions : `NR>1` ignore l'en-tête ; `$5!=""` garde les lignes dont la 5e colonne (serveur MX) n'est pas vide ; `$2!="cybernova.fr"` exclut le domaine original. L'action `print` affiche le domaine et son serveur de messagerie : les variantes capables d'envoyer du courrier.

Questions. (7) Quelles variantes ont un serveur de messagerie et pourquoi est-ce un signal fort ? (8) Un domaine simplement enregistré est-il forcément malveillant ? (9) Que faut-il faire de ces constats avant de contacter le registrar (séance 5) ?

4.7 Étape 3 — Auditer le certificat et la configuration TLS

Exercice K4.3 — sslscan et testssl.sh

K4.3 — sslscan : protocoles et chiffrements — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ sslscan --no-colour $CIBLE:443 | tee sslscan.txt | head -30
Version: 2.1.4
Connected to 203.0.113.10

Testing SSL server lab.cybernova.test on port 443 using SNI name lab.cybernova.test

  SSL/TLS Protocols:
SSLv2     disabled
SSLv3     disabled
TLSv1.0   enabled
TLSv1.1   enabled
```

```
TLSv1.2   enabled
TLSv1.3   enabled

  TLS Fallback SCSV:
Server supports TLS Fallback SCSV

  TLS renegotiation:
Secure session renegotiation supported

  Supported Server Cipher(s):
Preferred TLSv1.3  256 bits  TLS_AES_256_GCM_SHA384        Curve 25519 DHE 253
Accepted  TLSv1.2  256 bits  ECDHE-RSA-AES256-GCM-SHA384   Curve P-256 DHE 256
Accepted  TLSv1.2  128 bits  AES128-SHA
Accepted  TLSv1.0  128 bits  AES128-SHA
```

Signification des lignes de commande

Commande ou ligne	Signification
`sslscan --no-colour $CIBLE:443 | tee sslscan.txt | head -30`	`sslscan` teste les protocoles et suites de chiffrement acceptés par le serveur. `--no-colour` retire les codes de couleur pour un fichier propre ; `tee` enregistre la sortie complète ; `head -30` n'affiche que les 30 premières lignes à l'écran.
`SSLv2 / SSLv3 / TLSv1.0 / TLSv1.1 / TLSv1.2 / TLSv1.3`	Pour chaque version : `disabled` (vert) = bon ; `enabled` en rouge pour TLS 1.0 et 1.1 = protocoles dépréciés à désactiver.
`Preferred / Accepted … AES128-SHA`	Suites de chiffrement acceptées. Les suites `ECDHE` offrent la confidentialité persistante ; `AES128-SHA` (sans échange éphémère) est signalée en rouge.

K4.3 — testssl.sh : synthèse — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ testssl.sh --quiet --color 0 --logfile testssl.log $CIBLE:443 | grep -E "TLS 1 |TLS 1.1|
HSTS|Certificate Validity|Chain of trust|OCSP"
 TLS 1                     offered (deprecated)
 TLS 1.1                   offered (deprecated)
 Strict Transport Security  not offered
 Chain of trust            NOT ok (self signed CA in chain)
 Certificate Validity (UTC) 38 >= 30 days (2026-09-01 08:00 --> 2026-11-30 08:00)
 OCSP stapling             not offered
```

Signification des lignes de commande

Commande ou ligne	Signification
`testssl.sh --quiet --color 0 --logfile testssl.log $CIBLE:443 | grep -E "TLS 1 |TLS 1.1|HSTS| Certificate Validity|Chain of trust| OCSP"`	`testssl.sh` réalise un audit TLS détaillé. `--quiet` supprime la bannière ; `--color 0` désactive les couleurs ; `--logfile` conserve le journal complet ; `grep -E` n'affiche que les lignes clés : protocoles anciens, HSTS, validité du certificat, chaîne de confiance et agrafage OCSP.
`Certificate Validity (UTC) 38 >= 30 days`	Nombre de jours restants avant expiration (38) comparé au seuil d'alerte de 30 jours.

Questions. (10) Quelles versions de protocole sont à désactiver ? (11) Quels risques représentent TLS 1.0/1.1 et la suite `AES128-SHA` ? (12) Le certificat expire-t-il bientôt ? À quel seuil alerter ? (13) Que signifie l'absence de HSTS ?

4.8 Étape 4 — En-têtes HTTP de sécurité (`curl`)

Exercice K4.4 — Redirection HTTPS et HSTS

K4.4 — En-têtes HTTP — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ curl -sI http://$CIBLE | head -5
HTTP/1.1 301 Moved Permanently
Server: nginx
Date: Fri, 23 Oct 2026 07:58:21 GMT
Content-Type: text/html
Location: https://lab.cybernova.test/
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ curl -sI https://$CIBLE -k | grep -iE "strict-transport|content-security|x-frame|x-content-type|referrer-policy|permissions-policy"
x-content-type-options: nosniff
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ curl -sI https://$CIBLE -k | grep -ci "strict-transport-security"
0
```

Signification des lignes de commande

Commande ou ligne	Signification
`curl -sI http://$CIBLE | head -5`	`-s` : silencieux ; `-I` : requête `HEAD` qui ne récupère que les en-têtes. On teste le port 80 : `301` et `Location: https://…` montrent que la redirection vers HTTPS est en place. `head -5` limite l'affichage.
`curl -sI https://$CIBLE -k | grep -iE "strict-transport|content-security|x-frame|…"`	`-k` ignore la validation du certificat : acceptable **uniquement** dans le laboratoire dont l'autorité est non reconnue, jamais pour valider un site réel. `grep -iE` cherche, sans tenir compte de la casse, les en-têtes de sécurité attendus. Seul `x-content-type-options` est présent.
`curl -sI https://$CIBLE -k | grep -ci "strict-transport-security"`	`grep -c` compte les lignes trouvées : `0` = l'en-tête HSTS est absent.

Questions. (14) La redirection HTTP vers HTTPS est-elle en place ? (15) Quels en-têtes de sécurité sont absents ? (16) Quel est l'intérêt de HSTS contre l'interception au premier accès ?

4.9 Étape 5 — Mesurer l'exposition publique (`theHarvester` , laboratoire uniquement)

Exercice K4.5 — Ce qu'un attaquant apprend sans intrusion

`theHarvester` collecte des informations publiques à partir de sources ouvertes. Il n'est utilisé **que sur le domaine de laboratoire autorisé**. Les sources disponibles et leurs clés d'accès varient : le formateur précise la liste avant l'atelier.

K4.5 — theHarvester, sources ouvertes (lab) — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ theHarvester -d $CIBLE -b crtsh -l 100 -f harvester-lab
```

```
*******************************************************************
*  theHarvester 4.6.0                                             *
*******************************************************************

[*] Target: lab.cybernova.test

[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.

[*] Hosts found: 4
--------------------
lab.cybernova.test
www.lab.cybernova.test
mail.lab.cybernova.test
vpn-test.lab.cybernova.test
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ ls harvester-lab*
harvester-lab.json  harvester-lab.xml
```

Signification des lignes de commande

Commande ou ligne	Signification
`theHarvester -d $CIBLE -b crtsh -l 100 -f harvester-lab`	`-d` : domaine cible ; `-b crtsh` : source de données (les journaux de transparence des certificats) ; `-l 100` : limite à 100 résultats ; `-f` : préfixe des fichiers de sortie (JSON et XML). L'outil ne collecte que des informations publiques et n'est utilisé que sur le domaine de laboratoire.
`ls harvester-lab*`	Liste les fichiers produits, à conserver comme preuves. Un sous-domaine inattendu (rouge) est un point à vérifier avec le propriétaire.

Questions. (17) Quel sous-domaine mérite une vérification ? (18) Pourquoi les adresses e-mail éventuellement trouvées sont-elles des données personnelles ? (19) Qu'écririez-vous dans le rapport sur ce sous-domaine ?

4.10 Étape 6 — Figer les preuves et clore la session

K4.6 — Empreintes et clôture — kali@kali

```
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ exit
Script done.
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ sha256sum *.txt *.csv *.log *.json *.xml | tee empreintes-sha256.txt
3f1a9c...e2  dnsrecon-std.txt
b7d02e...41  dig-base.txt
0c5e88...7a  variantes.csv
a91b3d...f0  sslscan.txt
5e2c77...19  testssl.log
d40f16...b3  harvester-lab.json
┌──(kali㉿kali)-[~/audit-identite/2026-10-23]
└─$ chmod 440 *.txt *.csv *.log *.json *.xml && ls -l empreintes-sha256.txt
```

```
-r--r----- 1 kali kali 612 Oct 23 10:21 empreintes-sha256.txt
```

Signification des lignes de commande

Commande ou ligne	Signification
`exit`	Termine la session `script` : le journal `journal-session.txt` est alors complet.
`sha256sum *.txt *.csv *.log *.json *.xml | tee empreintes-sha256.txt`	Calcule l'empreinte de tous les fichiers de relevé (`*` = tous les fichiers d'une extension) et l'enregistre dans `empreintes-sha256.txt`. Toute modification ultérieure d'un fichier changerait son empreinte.
`chmod 440 *.txt *.csv *.log *.json *.xml && ls -l empreintes-sha256.txt`	`chmod 440` met les fichiers en lecture seule pour le propriétaire et le groupe, sans accès pour les autres. `ls -l` vérifie les droits (`-r--r-----`).

Les empreintes (`sha256`) permettent de démontrer plus tard que les fichiers n'ont pas été modifiés depuis l'audit.

4.11 Structure du rapport d'audit (livrable)

Partie	Contenu attendu
1. Contexte et périmètre	Domaine audité, autorisation, date, outils, environnement
2. Méthodologie	Commandes exécutées, horodatage, limites (techniques passives uniquement)
3. Constats	Tableau : élément, résultat observé, preuve (fichier ou capture)
4. Analyse des risques	Pour chaque constat : menace, gravité, probabilité, criticité
5. Recommandations	Mesures priorisées, justifiées, avec coût et délai estimés
6. Annexes	Sorties brutes des outils, captures d'écran, empreintes

Exemple de ligne de constat (à reproduire pour chaque point relevé) :

Élément	Constat	Preuve	Risque	Criticité	Recommandation
DMARC	Aucun enregistrement `_dmarc` publié	`dmarc.txt` (0 octet)	Spoofing du domaine sans politique de rejet	Élevée	Publier DMARC en `p=none` avec `rua`, durcir après analyse
TLS	TLS 1.0 et 1.1 activés	`sslscan.txt`	Chiffrement affaibli, non-conformité aux bonnes pratiques	Moyenne	Désactiver TLS 1.0/1.1, conserver 1.2 et 1.3

4.12 Critères d'évaluation du rapport (sur 20)

Critère	Points
Respect du cadre légal et du périmètre	3
Exactitude et reproductibilité des relevés	5

Distinction constat, risque, recommandation	4
Pertinence et priorisation des recommandations	5
Qualité de rédaction et de présentation	3

Corrigés de l'atelier K4

K4.1. (1) `ns1` et `ns2` du même domaine : un seul prestataire, point de dépendance unique. (2) `-all` : bonne pratique. (3) Non : la réponse est vide (0 octet). (4) Oui, limité à l'autorité du laboratoire. (5) Non : aucune clé DNSKEY, `dnsrecon` indique « DNSSEC is not configured ». (6) DMARC absent (élevé), DNSSEC absent (moyen), un seul prestataire DNS (faible à moyen), SPF et CAA conformes (points positifs à mentionner).

K4.2. (7) `cyber-nova.fr` et `cybernova-support.fr` : un MX actif permet d'envoyer et de recevoir du courrier crédible, signal fort d'usage pour du phishing. (8) Non : stationnement, revente ou domaine défensif d'un tiers de bonne foi sont possibles ; il faut des indices d'usage frauduleux. (9) Les documenter (captures, relevés DNS, dates) et calculer des empreintes, car les preuves disparaissent après la suppression du domaine.

K4.3. (10) TLS 1.0 et 1.1. (11) Protocoles dépréciés avec des faiblesses connues ; `AES128-SHA` n'offre pas la confidentialité persistante (pas d'échange de clés éphémère). (12) Expiration le 30 novembre 2026, soit 38 jours restants : seuil d'alerte courant à 30 jours, avec renouvellement automatisé. (13) Sans HSTS, un attaquant peut intercepter le premier accès en HTTP avant la redirection.

K4.4. (14) Oui (301 vers HTTPS). (15) HSTS, Content-Security-Policy, X-Frame-Options, Referrer-Policy, Permissions-Policy ; seul `x-content-type-options` est présent. (16) HSTS impose au navigateur d'utiliser HTTPS pour ce domaine pendant une durée donnée, ce qui supprime la fenêtre d'interception.

K4.5. (17) `vpn-test.lab.cybernova.test` : nom évocateur d'un service de test peut-être oublié et exposé ; à vérifier avec le propriétaire du laboratoire avant toute conclusion. (18) Elles identifient directement des personnes : à limiter, protéger et supprimer. (19) Constat : sous-domaine non documenté visible dans les journaux de transparence ; risque : service de test exposé ; recommandation : inventorier, vérifier la nécessité, supprimer ou protéger.

Séance 5 — Procédures de réaction et synthèse

Durée : 2 h · Atelier Kali K5 · Livrable : procédure de signalement d'usurpation

5.1 Objectifs pédagogiques

- Organiser la réaction à une usurpation d'identité numérique, dans l'ordre et avec les bons interlocuteurs.
- Conserver les preuves de façon exploitable (traçabilité, intégrité).
- Signaler et obtenir le retrait de contenus ou de domaines frauduleux.
- Articuler la réaction avec le RGPD et la communication de crise.
- Rédiger une procédure claire, utilisable par un service informatique.

5.2 Les cinq phases de la réaction

1. Détecter et qualifier	2. Contenir	3. Préserver les preuves	4. Signaler et faire retirer	5. Communiquer et améliorer
vérifier l'usurpation, mesurer l'ampleur, les victimes, les données	bloquer expéditeur et domaine, changer les mots de passe, révoquer les sessions	avant toute modification ou suppression	registrar, hébergeur, plateforme, autorités	informer, puis retour d'expérience

L'ordre compte : on préserve les preuves **avant** de faire retirer un contenu, car une fois le site fermé, les éléments disparaissent.

5.3 Préserver les preuves

Une preuve n'est utile que si l'on peut en démontrer l'authenticité et l'intégrité.

Preuve	Comment la conserver
Page web frauduleuse	Capture d'écran complète avec URL, date et heure visibles ; enregistrement de la page ; constat par un tiers (commissaire de justice) si l'enjeu le justifie
E-mail frauduleux	Message d'origine au format brut avec **en-têtes complets**, jamais un simple transfert
Faux compte ou publication	Captures datées, URL du profil et des publications, identifiants des comptes
Informations de domaine	Relevés DNS, informations d'enregistrement (WHOIS ou RDAP), certificats observés
Journaux techniques	Journaux de messagerie, proxy, pare-feu, serveur web, avec horodatage cohérent
Actions menées	Journal chronologique de toutes les décisions et actions (qui, quoi, quand)

Règles de base. Travailler sur des copies. Calculer une **empreinte** (SHA-256) de chaque fichier au moment du recueil. Tenir une **chaîne de conservation** : qui a eu la preuve, quand, pour quoi faire. Ne jamais modifier l'original. Enregistrer sur un support protégé en écriture ou à accès restreint. Dater en indiquant le fuseau horaire.

Atelier Kali K5 — Constituer un dossier de preuves exploitable (45 min)

Contexte : CyberNova a identifié le faux domaine `cyber-nova.fr`. Vous préparez, dans le laboratoire, le dossier à transmettre au registrar, à l'hébergeur et, si besoin, aux autorités. Aucune interaction avec le site frauduleux n'est nécessaire : on relève uniquement des informations publiques non intrusives.

Exercice K5.1 — Structurer le dossier et relever les données du domaine

K5.1 — Dossier de preuves — kali@kali

```
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/dossier-incident-2026-10-23/{messages,dns,whois,captures,journal} && cd ~/
dossier-incident-2026-10-23
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ ls
captures  dns  journal  messages  whois
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ cp ~/identite-numerique/2026-10-23/suspect.eml messages/ && chmod 444 messages/suspect.eml
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ for t in A MX NS TXT; do echo "== $t =="; dig cyber-nova.fr $t +short; done > dns/cyber-
nova.fr-dns.txt; cat dns/cyber-nova.fr-dns.txt
== A ==
203.0.113.77
== MX ==
10 mail.cyber-nova.fr.
== NS ==
ns.hosting.example.
== TXT ==
"v=spf1 ip4:203.0.113.77 -all"
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ whois cyber-nova.fr > whois/cyber-nova.fr-whois.txt; wc -l whois/cyber-nova.fr-whois.txt
32 whois/cyber-nova.fr-whois.txt
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ whois 203.0.113.77 | grep -iE "netname|descr|abuse|country" | tee whois/ip-203.0.113.77.txt
netname:        HOSTING-EXAMPLE-NET
descr:          Hosting Example SAS
country:        FR
abuse-mailbox:  abuse@hosting.example
```

Signification des lignes de commande

Commande ou ligne	Signification
`mkdir -p ~/dossier-incident-2026-10-23/{messages,dns,whois,captures,journal} && cd …`	Les accolades sont développées par le shell : une seule commande crée les cinq sous-dossiers. On range ainsi chaque type de preuve dans un dossier dédié.
`ls`	Vérifie la structure créée.
`cp …/suspect.eml messages/ && chmod 444 messages/suspect.eml`	Copie le message d'origine dans le dossier de preuves puis le passe en lecture seule pour tous (`444`).

`for t in A MX NS TXT; do … dig cyber-nova.fr $t +short; done > dns/cyber-nova.fr-dns.txt; cat …`	Boucle sur quatre types d'enregistrements ; `>` écrit l'ensemble dans un fichier de preuve DNS ; `cat` l'affiche pour contrôle. Le SPF du faux domaine n'autorise que l'adresse de l'hébergeur de l'attaquant.
`whois cyber-nova.fr > whois/cyber-nova.fr-whois.txt; wc -l …`	Enregistre les informations d'enregistrement du domaine ; `wc -l` compte les lignes pour vérifier que le fichier n'est pas vide.
`whois 203.0.113.77 | grep -iE "netname|descr|abuse|country" | tee whois/ip-203.0.113.77.txt`	Interroge la base des adresses IP pour identifier l'hébergeur ; `grep` garde le nom du réseau, la description, le pays et l'adresse `abuse` (contact pour signaler un abus) ; `tee` conserve le résultat.

Questions. (1) Pourquoi le fichier `suspect.eml` est-il passé en lecture seule ? (2) À quoi sert l'adresse `abuse-mailbox` relevée ? (3) Que révèle le SPF de `cyber-nova.fr` sur l'attaquant ?

Exercice K5.2 — Capturer la page en environnement isolé

La capture se fait **depuis la machine du laboratoire isolée**, avec un simple téléchargement de la page (sans formulaire, sans identifiant). L'horodatage figure dans le nom de fichier et dans le journal.

K5.2 — Enregistrement de la page et des en-têtes — kali@kali

```
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ date -u +%Y-%m-%dT%H:%M:%SZ | tee journal/horodatage-capture.txt
2026-10-23T08:34:05Z
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ curl -sS -D captures/entetes-http.txt -o captures/page-index.html --max-time 10 https://
cyber-nova.fr/
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ head -6 captures/entetes-http.txt
HTTP/2 200
server: nginx
date: Fri, 23 Oct 2026 08:34:06 GMT
content-type: text/html; charset=UTF-8
content-length: 14562
...
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ grep -oiE "<title>[^<]+" captures/page-index.html
<title>CyberNova - Espace client - Connexion
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ grep -ciE "type=\"password\"" captures/page-index.html
1
```

Signification des lignes de commande

Commande ou ligne	Signification
`date -u +%Y-%m-%dT%H:%M:%SZ | tee journal/horodatage-capture.txt`	`-u` : heure UTC ; le format `%Y-%m-%dT%H:%M:%SZ` donne un horodatage ISO non ambigu, conservé dans le journal.
`curl -sS -D captures/entetes-http.txt -o captures/page-index.html --max-time 10 https://cyber-nova.fr/`	`-s` silencieux, `-S` affiche tout de même les erreurs ; `-D` écrit les en-têtes de réponse dans un fichier ; `-o` enregistre le corps de la page ; `--max-time 10` abandonne après 10 secondes. Simple téléchargement, depuis la machine isolée : aucun formulaire n'est rempli et aucun lien suivi.
`head -6 captures/entetes-http.txt`	Affiche les premières lignes des en-têtes : code `200`, serveur, date de la réponse, type et taille du contenu.
`grep -oiE "<title>[^<]+" captures/page-index.html`	Extrait le titre de la page : `-o` seulement la partie trouvée, `-i` sans tenir compte de la casse. Le titre imite celui de l'espace client officiel.

`grep -ciE "type=\"password\"" captures/page-index.html`	`-c` compte les lignes contenant un champ de mot de passe : `1` = la page collecte des mots de passe.

Questions. (4) Pourquoi enregistre-t-on aussi les en-têtes HTTP ? (5) Que prouve la présence d'un champ `type="password"` dans une page qui copie le titre d'un site officiel ?

Exercice K5.3 — Calculer les empreintes et tenir la chaîne de conservation

K5.3 — Empreintes SHA-256 et journal — kali@kali

```
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ find . -type f ! -name 'empreintes-sha256.txt' -print0 | sort -z | xargs -0 sha256sum | tee
empreintes-sha256.txt
e3b0c4...55  ./captures/entetes-http.txt
4a1d2f...c8  ./captures/page-index.html
9f3c7b...02  ./dns/cyber-nova.fr-dns.txt
c0de5a...91  ./journal/horodatage-capture.txt
9c1f4a...c0  ./messages/suspect.eml
7b66d1...e4  ./whois/cyber-nova.fr-whois.txt
1e0a58...3d  ./whois/ip-203.0.113.77.txt
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ sha256sum -c empreintes-sha256.txt
./captures/entetes-http.txt: OK
./captures/page-index.html: OK
./dns/cyber-nova.fr-dns.txt: OK
./journal/horodatage-capture.txt: OK
./messages/suspect.eml: OK
./whois/cyber-nova.fr-whois.txt: OK
./whois/ip-203.0.113.77.txt: OK
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ printf '%s\n' "2026-10-23T08:41Z | i.twagirumukiza | Dossier constitue, 7 fichiers,
empreintes SHA-256 calculees" "2026-10-23T08:55Z | i.twagirumukiza | Transmis au RSSI (copie
chiffree sur support securise)" >> journal/chaine-de-conservation.txt
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ cat journal/chaine-de-conservation.txt
2026-10-23T08:41Z | i.twagirumukiza | Dossier constitue, 7 fichiers, empreintes SHA-256
calculees
2026-10-23T08:55Z | i.twagirumukiza | Transmis au RSSI (copie chiffree sur support securise)
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ tar czf dossier-incident-2026-10-23.tar.gz -C .. dossier-incident-2026-10-23 && sha256sum d
ossier-incident-2026-10-23.tar.gz
5d28b9e1f0a37c64e8b1d2f9a07c35e4b86a21d0c9f7e34a1b58c26d0e93f7a4  dossier-
incident-2026-10-23.tar.gz
```

Signification des lignes de commande

Commande ou ligne	Signification
`find . -type f ! -name 'empreintes-sha256.txt' -print0 | sort -z | xargs -0 sha256sum | tee empreintes-sha256.txt`	`find . -type f` liste les fichiers du dossier ; `! -name …` exclut le fichier d'empreintes lui-même. `-print0`, `sort -z` et `xargs -0` utilisent un séparateur nul, sûr même pour des noms avec espaces. `xargs` passe la liste à `sha256sum` ; `tee` conserve le résultat.
`sha256sum -c empreintes-sha256.txt`	`-c` (check) recalcule chaque empreinte et la compare à celle du fichier : `OK` = inchangé, `FAILED` = modifié.
`printf '%s\n' "…" "…" >> journal/chaine-de-conservation.txt`	`printf '%s\n'` écrit chaque argument sur sa propre ligne ; `>>` ajoute à la fin du fichier sans l'écraser. Chaque ligne note date, personne et action : c'est la chaîne de conservation.
`cat journal/chaine-de-conservation.txt`	Relit le journal pour contrôle.

`tar czf dossier-incident-2026-10-23.tar.gz -C .. dossier-incident-2026-10-23 && sha256sum dossier-incident-2026-10-23.tar.gz`	`tar czf` : **c**réer une archive, la compresser en **z** (gzip), dans le **f**ichier indiqué. `-C ..` se place dans le dossier parent pour éviter des chemins absolus. La dernière commande calcule l'empreinte de l'archive complète, à communiquer avec elle.

Questions. (6) À quoi sert la vérification `sha256sum -c` ? (7) Que se passerait-il si un seul octet de `page-index.html` était modifié ? (8) Pourquoi ajoute-t-on une empreinte de l'archive complète ?

Exercice K5.4 — Rédiger le signalement au registrar

K5.4 — Modèle de signalement — kali@kali

```
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ nano signalement-registrar.txt
(édition du fichier : voir le travail demandé ci-dessous)
┌──(kali㉿kali)-[~/dossier-incident-2026-10-23]
└─$ head -3 signalement-registrar.txt
Objet : Signalement d'usurpation d'identité - domaine cyber-nova.fr
Plaignant : CyberNova (domaine officiel : cybernova.fr)
Pièces jointes : dossier-incident-2026-10-23.tar.gz (SHA-256 communiqué dans le corps du
message)
```

Signification des lignes de commande

Commande ou ligne	Signification
`nano signalement-registrar.txt`	Ouvre l'éditeur `nano` pour rédiger le signalement. Le texte à saisir est décrit dans le travail demandé.
`head -3 signalement-registrar.txt`	Affiche les trois premières lignes du fichier : objet, plaignant et pièces jointes avec l'archive de preuves.

Travail demandé. Complétez le signalement avec : l'identité de la société plaignante et ses droits (marque, nom de domaine officiel `cybernova.fr`) ; la description factuelle (date de création du domaine, page imitant l'espace client, collecte d'identifiants) ; la liste des pièces jointes avec leur empreinte ; la demande précise (suspension du domaine, conservation des données d'enregistrement) ; le contact de référence. Restez factuel : n'accusez pas nominativement un tiers sans élément solide.

5.4 Signaler et obtenir le retrait

Interlocuteur	Pour quoi	Éléments à fournir
Bureau d'enregistrement (registrar)	Suspension ou transfert du domaine	Preuves de l'usurpation, justificatif de droit sur la marque
Hébergeur du site	Retrait du contenu	Adresse du site, preuves, motif
Plateforme sociale, boutique d'applications	Suppression du faux compte ou de l'application	Pièce justifiant l'identité de l'organisation, liens vers les contenus
Fournisseur de messagerie, passerelle anti-spam	Blocage de l'expéditeur ou du domaine	En-têtes, exemples de messages

Navigateurs et listes de blocage	Alerte aux internautes	URL, preuves
Plateformes officielles de signalement (Cybermalveillance.gouv.fr, Signal Spam, PHAROS pour les contenus illicites)	Assistance, signalement, enquête	Description des faits et des preuves
Police ou gendarmerie	Dépôt de plainte	Dossier de preuves, préjudice
CNIL	Notification de violation de données personnelles, si les conditions sont réunies	Voir 5.5
Assureur	Déclaration de sinistre	Délais et pièces prévus au contrat
Conseil juridique, prestataire anti-contrefaçon de marque	Mise en demeure, procédures extrajudiciaires ou judiciaires	Dossier de preuves, titres de propriété de la marque

Les noms et procédures de ces services évoluent : **vérifiez les coordonnées et formulaires à jour** et consignez-les dans la procédure interne plutôt que de les citer de mémoire.

5.5 Lien avec le RGPD

Si des clients ou des salariés ont saisi des données personnelles sur un faux site, ou si un compte officiel compromis a servi à en collecter, analysez s'il y a une **violation de données personnelles**. Rappel du Thème 1 : si la violation est susceptible d'engendrer un risque pour les droits et libertés des personnes, notification à la CNIL dans les 72 heures après en avoir pris connaissance ; si le risque est élevé, information des personnes concernées. Dans tous les cas, la violation est consignée dans le registre des violations. La qualification (violation de l'organisation elle-même ou seulement imitation par un tiers) doit être analysée avec le délégué à la protection des données (DPO) ou le service juridique.

5.6 Communication de crise

- **Interne** : consignes rapides aux salariés (ne pas répondre aux messages suspects, remonter les signalements, qui parle à l'extérieur).
- **Clients et partenaires** : message clair et factuel : ce qui s'est passé, ce qu'il faut faire (ne pas utiliser tel site, changer tel mot de passe), comment joindre l'organisation, quels sont les canaux officiels.
- **Public et médias** : communiqué validé par la direction, porte-parole unique, canaux officiels annoncés.
- **Principes** : transparence proportionnée, rapidité, cohérence, exactitude. On ne communique que des faits vérifiés.

À éviter : minimiser sans preuve, accuser publiquement un tiers sans élément solide (risque de diffamation), publier des détails techniques exploitables par d'autres attaquants.

5.7 Procédure type de signalement d'usurpation (livrable : modèle)

Modèle de procédure (à compléter) — kali@kali

```
┌──(kali㉿kali)-[~/procedures]
└─$ cat procedure-signalement-usurpation.txt
PROCÉDURE — Signalement d'une usurpation d'identité numérique
Organisation : CyberNova      Version : 1.0      Date : ____
Responsable : RSSI / DSI      Suppléant : ____

1. DÉCLENCHEURS
   - Domaine, compte ou application imitant l'organisation
   - Message frauduleux reçu par des clients ou des salariés
   - Alerte d'un outil de surveillance

2. ALERTE  Service sécurité : ____  Direction : ____  DPO : ____

3. QUALIFICATION (en 30 min)
   - Nature : domaine / compte / message / site / application
   - Données concernées ? Victimes connues ?
   - Niveau : faible / moyen / élevé / critique

4. CONFINEMENT
   - Bloquer l'expéditeur et le domaine (messagerie, proxy)
   - Compte officiel compromis : changer les identifiants, révoquer les sessions

5. PRÉSERVATION DES PREUVES (avant tout retrait)
   - Captures datées, e-mails bruts, URL, relevés DNS
   - Empreintes SHA-256, chaîne de conservation

6. SIGNALEMENT ET RETRAIT
   - Registrar / hébergeur / plateforme : formulaire + preuves
   - Plateformes officielles de signalement ; plainte si préjudice

7. OBLIGATIONS LÉGALES
   - Analyse RGPD avec le DPO (72 h CNIL si applicable)
   - Déclaration à l'assureur si le contrat le prévoit

8. COMMUNICATION   Interne / clients et partenaires / public : messages validés

9. CLÔTURE ET AMÉLIORATION
   - Retour d'expérience sous 15 jours ; mise à jour des protections (séance 3)
```

Signification des lignes de commande

Commande ou ligne	Signification
`cat procedure-signalement-usurpation.txt`	`cat` affiche le modèle de procédure. Les titres sont en cyan ; les niveaux de gravité sont colorés du vert (faible) au rouge (critique) pour une lecture rapide. Chaque rubrique (déclencheurs, alerte, qualification, confinement, preuves, signalement, obligations, communication, clôture) correspond à une phase de la réaction décrite en 5.2.

5.8 Étude de cas finale (évaluation sommative, 45 min)

Situation. Une entreprise découvre un faux domaine, un compte social frauduleux et des messages accusant publiquement son service client de pratiques malhonnêtes. Plusieurs clients ont saisi leurs informations personnelles sur le faux site.

1. Identifier les composantes de l'identité numérique concernées.
2. Distinguer les menaces techniques, réputationnelles et juridiques.

3. Évaluer les conséquences possibles pour les clients et pour l'entreprise.
4. Indiquer les preuves à conserver et la façon de les conserver.
5. Proposer des mesures immédiates et des actions préventives.
6. Justifier les priorités en fonction du risque.

Corrigés de la séance 5

K5.1. (1) Pour empêcher toute modification accidentelle : l'original reste intact et on travaille sur des copies. (2) À adresser le signalement à la bonne équipe de l'hébergeur, qui peut suspendre le serveur. (3) Le SPF n'autorise que l'adresse `203.0.113.77` : la même infrastructure sert à l'envoi des messages et à l'hébergement, ce qui relie le site et les e-mails.

K5.2. (4) Les en-têtes prouvent la réponse du serveur à une date précise (statut, serveur, date) et complètent la capture. (5) Une page de connexion qui imite l'espace client officiel et collecte un mot de passe confirme l'intention de collecte d'identifiants (hameçonnage) : à qualifier comme tel, sans conclure sur l'identité de l'auteur.

K5.3. (6) À contrôler que les fichiers n'ont pas changé depuis le calcul des empreintes. (7) L'empreinte ne correspondrait plus : la commande indiquerait `FAILED` pour ce fichier, la preuve perdrait sa valeur. (8) Pour prouver l'intégrité de l'ensemble transmis, en plus de chaque fichier.

K5.4. Éléments attendus : plaignant et droits (marque, domaine officiel) ; faits datés (domaine créé le 19 octobre 2026, page imitant l'espace client, collecte d'identifiants) ; pièces jointes listées avec empreintes ; demande de suspension et de conservation des données d'enregistrement ; contact. Ton factuel et sans accusation nominative.

Étude de cas. 1 : nom de domaine (faux domaine), comptes officiels et marque (faux compte), e-réputation (accusations publiques). 2 : technique (typosquatting, faux site de collecte), réputationnelle (faux compte, messages accusateurs), juridique (usurpation, éventuelle diffamation ou dénigrement selon le contenu). 3 : clients (vol d'identifiants, fraude, hameçonnage ultérieur) ; entreprise (perte de confiance, coûts de remédiation, obligations RGPD, risque contentieux). 4 : captures datées, URL, messages originaux avec en-têtes, relevés DNS et d'enregistrement, empreintes SHA-256, journal des actions. 5 : immédiat = confinement, préservation des preuves, signalement (registrar, hébergeur, plateforme), information des clients, analyse RGPD avec le DPO ; préventif = MFA, SPF/DKIM/DMARC, surveillance de marque, réservation défensive, sensibilisation. 6 : priorité aux personnes déjà exposées, puis à la coupure de la source (retrait du faux site), puis aux mesures durables, justifiée par la criticité (gravité × probabilité) et le coût.

5.9 Synthèse du thème

Séance	Idée maîtrisée
1	L'identité numérique est un ensemble de composants techniques, organisationnels et réputationnels, déclaratifs, agissants et calculés.
2	Elle est attaquée par imitation, détournement et atteinte à la réputation, souvent sans intrusion dans le système d'information.
3	Elle se protège en couches : prévenir, détecter, réagir, avec des mesures proportionnées au risque.
4	Un audit passif, dans un cadre autorisé, mesure l'exposition réelle.

5	Une procédure testée permet de réagir vite, de prouver et de communiquer.

Ce thème prépare la suite du programme : le Thème 3 reprend le phishing, la MFA et l'accès distant ; le Thème 4 la collecte de preuves, les sauvegardes et la réponse à incident de premier niveau.

Annexes

A. Méthode de réponse à une question d'examen BTS SIO

Face à un document technique (extrait DNS, certificat, en-tête d'e-mail, sortie de console, fiche d'incident), suivez toujours la même démarche :

1. **Identifier** l'élément observé : domaine, enregistrement DNS, certificat, compte officiel, message.
2. **Décrire** ce que le document contient réellement, en citant les éléments précis (valeurs, dates, noms).
3. **Repérer** l'anomalie ou le risque éventuel.
4. **Expliquer** les conséquences pour l'organisation (technique, financière, juridique, réputationnelle).
5. **Proposer** une mesure adaptée et **justifier** son utilité, avec le bénéfice attendu.

> **Exemple rédigé**
>
> Sortie de console : `notAfter=Nov 30 08:00:00 2026 GMT` . Je relève la date de fin de validité du certificat, soit le 30 novembre 2026. Si le certificat n'est pas renouvelé avant cette date, les navigateurs afficheront un avertissement et le service sera interrompu pour les utilisateurs. Je recommande un renouvellement automatisé et une alerte de supervision 30 jours avant l'échéance. Bénéfice attendu : continuité du service et maintien de la confiance des utilisateurs.

Erreurs fréquentes à éviter : conclure qu'un site est sûr parce qu'il affiche un cadenas ; confondre MX (réception) et SPF (émission) ; citer un texte de loi ou un chiffre sans source ; proposer une mesure sans la relier à un risque du dossier ; mélanger constat et interprétation.

B. Aide-mémoire des commandes Kali du thème

Aide-mémoire — kali@kali

```
┌──(kali㉿kali)-[~]
└─$ dig domaine.tld A +short                # adresse IPv4
┌──(kali㉿kali)-[~]
└─$ dig domaine.tld MX +short               # serveurs de messagerie
┌──(kali㉿kali)-[~]
└─$ dig domaine.tld TXT +short              # SPF et vérifications
┌──(kali㉿kali)-[~]
└─$ dig _dmarc.domaine.tld TXT +short       # politique DMARC
┌──(kali㉿kali)-[~]
└─$ dig selecteur._domainkey.domaine.tld TXT +short   # clé publique DKIM
┌──(kali㉿kali)-[~]
└─$ dig domaine.tld CAA +short              # autorités autorisées
┌──(kali㉿kali)-[~]
└─$ dig domaine.tld DNSKEY +short           # présence de DNSSEC
┌──(kali㉿kali)-[~]
└─$ dnsrecon -d domaine.tld -t std          # énumération DNS standard
┌──(kali㉿kali)-[~]
└─$ dnstwist --registered domaine.tld       # variantes enregistrées
┌──(kali㉿kali)-[~]
└─$ openssl s_client -connect domaine.tld:443 -servername domaine.tld </dev/null 2>/dev/null | opens
sl x509 -noout -subject -issuer -dates
┌──(kali㉿kali)-[~]
└─$ sslscan domaine.tld:443                 # protocoles et chiffrements
```

```
┌──(kali㉿kali)-[~]
└─$ testssl.sh --quiet domaine.tld:443       # audit TLS détaillé
┌──(kali㉿kali)-[~]
└─$ curl -sI https://domaine.tld             # en-têtes HTTP
┌──(kali㉿kali)-[~]
└─$ whois domaine.tld                        # informations d'enregistrement
┌──(kali㉿kali)-[~]
└─$ sha256sum fichier                        # empreinte d'intégrité
┌──(kali㉿kali)-[~]
└─$ sha256sum -c empreintes-sha256.txt       # vérification des empreintes
```

Signification des lignes de commande

Commande ou ligne	Signification
`dig … +short`	Option commune à presque toutes les requêtes : n'affiche que la valeur de la réponse.
`dig _dmarc.… / selecteur._domainkey.…`	DMARC et DKIM se publient sous des noms particuliers (préfixes `_dmarc` et `…_domainkey`).
`openssl s_client … </dev/null 2>/dev/null | openssl x509 -noout …`	Ouvre une connexion TLS sans saisie ni messages d'erreur, puis décode le certificat reçu.
`sha256sum fichier / sha256sum -c empreintes`	Calcule l'empreinte d'un fichier / vérifie une liste d'empreintes enregistrées.
`Texte après #`	Les commentaires (en gris) rappellent le rôle de chaque commande ; le shell les ignore.

> **Rappel**
> Ces commandes ne s'appliquent qu'à des domaines que vous possédez, à des domaines d'exemple ou au laboratoire autorisé.

C. QCM de synthèse du thème (12 questions)

1. L'identité numérique **agissante** correspond : a) à ce que l'organisation publie volontairement ; b) aux traces laissées par ses activités en ligne ; c) aux déductions calculées par des algorithmes.
2. Un certificat TLS valide prouve que : a) le site est honnête ; b) le site appartient à l'organisation imitée ; c) le serveur présente un certificat valide pour le nom de domaine consulté.
3. Dans `www.cybernova.fr.paiement-secure.example`, le domaine réel est : a) `cybernova.fr` ; b) `paiement-secure.example` ; c) `www`.
4. Un enregistrement MX sert à : a) indiquer les serveurs de réception des e-mails ; b) signer les e-mails ; c) chiffrer le site web.
5. SPF permet : a) de signer cryptographiquement les messages ; b) de déclarer les serveurs autorisés à envoyer du courrier pour le domaine ; c) de chiffrer les messages.
6. DMARC permet notamment : a) de définir la conduite à tenir en cas d'échec d'authentification et de recevoir des rapports ; b) de renouveler un certificat ; c) de masquer l'adresse IP du serveur.
7. La valeur DMARC `p=none` : a) rejette tous les messages en échec ; b) place les messages en quarantaine ; c) n'applique aucune action et sert à observer.
8. La défiguration d'un site est : a) l'enregistrement d'un domaine proche ; b) la modification non autorisée du contenu d'un site réel ; c) l'expiration d'un certificat.

9. DNSSEC garantit : a) la confidentialité des requêtes DNS ; b) l'authenticité et l'intégrité des réponses DNS ; c) l'honnêteté du propriétaire du domaine.
10. Avant de demander la fermeture d'un site frauduleux, il faut : a) attendre qu'il soit fermé par lui-même ; b) préserver les preuves (captures datées, empreintes, journal) ; c) y saisir de fausses données pour le tester.
11. DMARC protège : a) le domaine de l'organisation contre l'usurpation de l'expéditeur, mais pas l'enregistrement de domaines proches ; b) tous les domaines ressemblant au vôtre ; c) les comptes de réseaux sociaux.
12. Pour une demande de virement reçue par e-mail, la bonne pratique est de : a) répondre à l'expéditeur pour confirmer ; b) confirmer par un second canal connu ; c) payer rapidement pour éviter la pénalité.

> **Corrigé du QCM**
> 1-b ; 2-c ; 3-b ; 4-a ; 5-b ; 6-a ; 7-c ; 8-b ; 9-b ; 10-b ; 11-a ; 12-b.

D. Grille d'évaluation de la fiche d'identité numérique (séance 1)

Critère	Attendu	Points
Exhaustivité	Domaines, certificats, comptes officiels, marque, messagerie recensés	6
Exactitude	Relevés DNS et TLS corrects et datés	5
Analyse	Risques identifiés pour chaque composant	5
Mesures	Premières protections proposées et justifiées	4

E. Glossaire

Terme	Définition
AAAA	Enregistrement DNS associant un nom à une adresse IPv6
Autorité de certification	Organisme qui délivre et signe des certificats numériques
CAA	Enregistrement DNS limitant les autorités autorisées à émettre des certificats pour un domaine
Certificate Transparency	Système de journaux publics des certificats émis
Chaîne de conservation	Traçabilité de qui a détenu une preuve, quand et pourquoi
CNAME	Alias DNS vers un autre nom
Défiguration	Modification non autorisée du contenu d'un site web
DKIM	Mécanisme de signature cryptographique des e-mails
DMARC	Politique de traitement des e-mails en échec d'authentification, avec rapports
DNS	Système de noms de domaine
DNSSEC	Extension de sécurité du DNS par signatures cryptographiques

E-réputation	Image et opinion d'une organisation en ligne
HSTS	En-tête imposant au navigateur d'utiliser HTTPS pour un domaine
Homographe (attaque par)	Imitation par des caractères visuellement identiques d'autres alphabets
IDN	Nom de domaine internationalisé, utilisant des caractères non latins
MFA	Authentification multifacteur
MX	Enregistrement DNS désignant les serveurs de réception des e-mails
Registrar	Bureau d'enregistrement auprès duquel un domaine est réservé
SPF	Mécanisme déclarant les serveurs autorisés à envoyer du courrier pour un domaine
Spear phishing	Hameçonnage personnalisé visant une cible précise
Spoofing	Falsification de l'expéditeur ou de l'origine d'un message
TLS	Protocole de chiffrement des communications, successeur de SSL
TTL	Durée de vie, en secondes, d'un enregistrement DNS en cache
Typosquatting	Enregistrement d'un domaine proche d'un domaine légitime pour tromper

F. Points de vigilance pour le formateur

- **Textes juridiques et chiffres** : vérifier avant chaque année scolaire les références (Code pénal, loi sur la liberté de la presse, RGPD) et les statistiques de baromètres. Ce cours ne donne volontairement aucune sanction chiffrée ni délai de prescription.
- **Sorties de console** : les sorties sont des simulations sur des domaines et adresses fictifs. Les options et la présentation de `dnstwist`, `testssl.sh`, `theHarvester` et `dnsrecon` changent avec les versions : tester chaque atelier dans le laboratoire avant la séance.
- **Laboratoire** : le domaine `lab.cybernova.test` doit être configuré par l'établissement (DNS, serveur web, messagerie, autorité de certification de laboratoire) ; les exercices K3.3, K4.2 et K5 supposent un accès contrôlé et validé.
- **Données personnelles** : supprimer en fin d'atelier toute adresse e-mail réelle éventuellement collectée.
- **Lien avec le programme** : Thème 1 (RGPD, notification, analyse de risques), Thème 3 (phishing, MFA), Thème 4 (preuves, sauvegardes, réponse à incident).